

**ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00**

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
May 2026	All	All	Jessica Lin	Created the audit program

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

Table of Contents

PROCESS AND OBJECTIVE	4
PLANNING: Audit Program Risk Alignment	5
PLANNING: Data Analysis	7
PLANNING: Self-Service Report	10
PLANNING: Reference Material	11
PLANNING: Fraud Template	13
CONTROL ASSESSMENT QUESTIONS	15
Key Control Question: 1. Data Privacy and Protection	15
Primary Test: Data Security and Privacy (DP001.P)	16
Primary Test: Separation of Duties (DP002.P)	18
Key Control Question: 2. Financial Management	19
Primary Test: Revenue Recognition (FM001.P)	20
Primary Test: Contract Performance (FM002.P)	22
Primary Test: Bank Account Management (FM003.P)	23
Key Control Question: 3. Local Regulation and Oversight	24
Primary Test: Local Controls and Regulations (LC001.P)	25
Primary Test: Involvement with Government Officials (LC002.P)	27
Key Control Question: 4. Security Access Management	28
Primary Test: Security Access Management (AM001.P)	29
Key Control Question: 5. FIN 122 Integration Compliance	30
Primary Test: FIN 122 Integration Compliance (IC001.P)	31
Primary Test: Integration Plan (IC002.P) (only applicable for old FIN 122)	33
Primary Test: Communication Strategy (IC003.P) (only applicable for old FIN 122)	34
Primary Test: GPO Oversight and Governance to ToB (IC004.P) (only applicable for old FIN 122)	35
Key Control Question: 6. Human Resources (HR)	37
Primary Test: Payroll (HR001.P)	38
Primary Test: Compensation (HR002.P)	39
Primary Test: Benefits (HR003.P)	40
Primary Test: Pension Benefits (HR004.P)	41
Primary Test: Employee Reimbursements (HR005.P)	43
Key Control Question: 7. Product Development and Research Projects	44
Primary Test: Product Development (PD001.P)	45
Key Control Question: 8. Solution Delivery	46
Primary Test: Contract Proposal Acceptance and Fulfillment (SD001.P)	47
Primary Test: Deliverables (SD002.P)	48

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

Primary Test: Contract Change and Request for Services (SD003.P)	50
Primary Test: Billing (SD004.P).....	52
Primary Test: Accounts Receivable (SD005.P)	53
Primary Test: Labor Claiming and Work at Risk (SD006.P).....	54
Key Control Question: 9. Solution Design.....	55
Primary Test: Contract Design and Agreement (DS001.P).....	56
Primary Test: Solution Design Mandatories (DS002.P).....	58
Key Control Question: 10. Vendor Management.....	59
Primary Test: Supplier Selection (PR001.P)	60
Primary Test: Purchase Order Process (PR002.P).....	64
Primary Test: Contract Administration (PR003.P)	66
Primary Test: Approval of Commitments (PR004.P)	68
Primary Test: Procurement Bypass (PR005.P)	69
Primary Test: Supplier Assessment (PR006.P).....	70
Primary Test: Accounts Payable (PR007.P).....	71
Key Control Question: 11. Facilities Operations (includes Energy Management and Safety).73	
Primary Test: Primary Test: Building Maintenance and Operations (FO001.P).....	74
Primary Test: Assets (FO002.P).....	75
Primary Test: Safety (FO003.P).....	76

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

PROCESS AND OBJECTIVE

The companies (Acquired Entities), operations, assets and majority interests IBM acquired (collectively, “Acquired Operations”) often do not maintain business, legal, data/security compliance, and operational processes and safeguards comparable to those of IBM. As a result, the continued stand-alone operation of Acquired Operations may impose increased financial, security, legal, and reputational risks to IBM. It is desirable that Acquired Operations and Entities be fully integrated into IBM as quickly as practicable. Retained entities persist beyond business integration to conduct limited operations, which are approved by IBM Treasury for a specified duration, allowing for any remaining contracts, vendor relationships, or assets that require further action to be moved out of the legal entity. These entities are referred to as Acquired and Retained Entities throughout this document.

A tailored approach is required for auditing an acquired or retained entity to identify the entity’s operational independence and potential deviation from IBM’s standard governance framework. When an acquired entity is fully integrated into IBM, its processes would be incorporated into the mainline business, which is covered in the mainline business’ audit instead. When an acquired entity has not fully integrated or has just integrated during the audit period, verify the timeliness and completeness of Corporate Instruction Finance 122 compliance within applicable IBM global processes.

Auditors must:

- Understand the rationale for non-integration for the retained entity, which was approved via IBM Treasury’s Legal Entity review process.
 - Identify controls implemented to manage deliverables and contractual obligations.
 - Evaluate the oversight and risk mitigation.
 - Consider the heightened risk of control gaps, inconsistent documentation, and limited visibility into performance metrics.
- Leverage risk conversations with key personnel to gain insights into processes, controls, and oversight. Conduct a comprehensive risk assessment to identify control gaps, process deviations, and limited visibility into operational performance.
- Benchmark against IBM’s standard processes to identify discrepancies and improvement opportunities.

Audit team lead (ATL) must:

- Identify integrated and non-integrated processes during the preparation. Due to time and resource constraints, it is essential to include processes to be audited to a manageable level. Other than non-integrated processes, high-risk integrated processes which have not been covered in recent audits may be in scope. For defined risk areas, input the evaluation as one of the three evaluation ratings, not assessed, or not applicable (if integrated and not managed by the entity).
- Data Privacy and Security, Access Management, and FIN 122 Integration Compliance cannot be descope.
- During an integrated audit, use IT audit protocols and make evaluations under IT audit for the risk areas of Access Management and Data Privacy and Security to avoid duplication.
- The GPO is responsible for ensuring that processes are properly designed, controlled, and integrated into IBM’s broader governance framework. When there is heightened risk of control gaps, evaluate the GPO’s involvement in oversight and risk mitigation actions within their functional areas and include the GPO/Senior Functional Leader in the report recommendation and the report (add in the distribution list). After the report is published, assign the GPO as the responder delegate for the recommendation the GPO is responsible for.

The following example shows how to capture the GPO in a recommendation to address control gaps in procurement process:

Partner with the Senior Functional Leader of Procurement (name of the senior functional leader) to strengthen supplier management controls to ensure adherence to the established procurement policies and procedures.

Link to the list of Senior Functional Leaders: <https://w3.ibm.com/w3publisher/corpdev/fin122-page/gpo-ma-leaders>

**ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00**

PLANNING: Audit Program Risk Alignment

Acquired and Retained Entities

Defined Risk Area	Risk Level	Key Control Question	Test Number
Data Privacy and Security	High	Data Privacy and Security	DP001.P, DP002.P
Financial Management	High	Financial Management	FM001.P, FM002.P, FM003.P
Local Regulation and Oversight	High	Local Regulation and Oversight	LC001.P, LC002.P
Access Management	Medium	Security Access Management	AM001.P
FIN 122 Integration Compliance	Medium	FIN 122 Integration Compliance	IC001.P, IC002.P, IC003.P, IC004.P
Human Resources	Medium	Human Resources	HR001.P, HR002.P, HR003.P, HR004.P, HR005.P
Product Development and Research Projects	Medium	Product Development	PD001.P
Solution Delivery	Medium	Solution Delivery	SD001.P, SD002.P, SD003.P, SD041.P, SD005.P, SD006.P
Solution Design	Medium	Solution Design	DS001.P, DS002.P
Vendor Management	Medium	Vendor Management	PR001.P, PR002.P, PR003.P, PR004.P, PR005.P, PR006.P, PR007.P
Facilities Operations (includes Energy Management and Safety)	Low	Facilities Operations (includes Energy Management and Safety)	FO001.P, FP002.P, FP003.P

**ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00**

PLANNING: Audit Program Risk Alignment (continued)

The following table exhibits the mapping of the most critical areas of Internal Controls and CA&AS process audit defined risk areas.

Internal Controls Most Critical Areas for Acquired and Retained Entities		CA&AS Process Audit Defined Risk Areas* for Acquired and Retained Entities
Function	Process	
1. Accounting	1. Accounting	Financial Management
2. Finance	2. Cost	
	3. Revenue	
	4. Global Services Signings & Backlog	
3. Global Real Estate	5. Real Estate	Facilities Operations (includes Energy Management and Safety)
4. Human Resources	6. Global Compensation	Human Resources
	7. Payroll	
	8. H&W (Benefits) / Pension	
5. IT – Business Owned	9. IT	Data Privacy and Security
6. IT – CISO/BISO		
7. IT – CIO Owned		
8. Legal and Regulatory Affairs	10. Government and Regulatory Affairs	Local Regulation and Oversight
	11. Site Security	Access Management
9. Procurement	12. Accounts Payable	Vendor Management
	13. Procurement	
10. Quote to Cash	14. Accounts Receivable	Solution Delivery
11. Tax	15. Tax	Financial Management
12. Treasury	16. Treasury Operations	Financial Management
13. Consulting	Add-on: Solution Design & Delivery	• Solution Design • Solution Delivery
14. Software	Add-on: Product Development & Technology	Product Development and Research Projects
*Defined risk areas to be added: (1) FIN 122 Integration Compliance and Evergreen risk areas. (2) When an integrated audit is performed, additional IT risk areas are included. Also, Audit team lead should use IT audit protocols and make evaluations under IT audit for the risk areas of Access Management and Data Privacy and Security to avoid duplication.		

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Concern
Revenue Recognition Manual entries - request detailed ledger extract for all manual entries Balance sheet account reconciliations - request list of all balance sheet accounts reconciled in and outside of the Asset Reuse Manager (ARM) tool.	Review ledger entries report paying attention to: - Material manual revenue and cost deferrals and accruals - Revenue reversals, negative revenue in the month after end of quarter - Manual credits and provisions - Contracts with negative revenue in the month following quarter end - Perform analysis based on variance and content aging items, operational and variance balances, the timing reconciliations were performed and look at the same reconciliations month to month.	- Unsupported accounting entries, with insufficient review by either management or Accounting resulting in inaccurate revenue or gross profit (GP), which could in turn impact incentive or commission payments. - Unidentified activity could be occurring in accounts. Lack of sufficient documentation to explain and resolve variances could lead to financial misstatements.
Bank Accounts Universe of bank accounts active during the audit period	Compare bank accounts in ledger (IT may pull out the data) and in FIS-eBAM	- Accounts closed in FIS-eBAM have not been closed in ledger and vice versa. - Accounts opened in FIS-eBAM have not been opened in ledger and vice versa. - For accounts in FIS-eBAM and not in ledger, cash transactions may not be recorded appropriately. For accounts in ledger and not in FIS-eBAM, could be a FIN181 violation.

**ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00**

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Concern
Access Management A list of all employees who left the company during the audit period, including accesses granted and removal details.	Inappropriate accesses, including access after separation or job change	Ineffective access controls could lead to misuse of intellectual and physical assets or create an insecure work environment for personnel.
FIN 122 Compliance The status of integration deliverables/tasks and business integration dashboard for the auditable entity (the DealMobilizer tool was used to monitor and sign off the task completion after January 6, 2026; exceptions require approvals)	Verify FIN 122 compliance To see if CBI tasks were completed within the required timeline with artifacts of completion. To see if the extension process was followed.	Insufficient monitoring to ensure timely and complete business integration may impose increased financial, security, legal, and reputational risks to IBM.
Solution Design and Solution Delivery Universe of all contracts signed during the audit period should be provided, including: - Total contract value - Business Transaction Type (BTT) rating - Date of signature of contract - Whether contract status was classified as troubled - Customer satisfaction result - Problem Management Record (PMR) result	Select contract samples to review the following: - Significant variances to pricing case - Quality assurance (QA) issues documented in QA reviews - Correct pricing approvals were in place (following pricing delegations) - Credit approvals were obtained for TCV before issuance of proposal to customer and were valid at time of contract signature - Legal approvals were in place for non-standard terms and conditions - Customer acceptance of contracts was in place and submissions to fulfillment on contract registration were sent with all required inputs. - Low customer satisfaction, material claims/settlements and complaints Financial indicators of risk including: - High amounts of aged debt, and disputed invoices - High value of write offs - Whether deliverables were properly tracked and executed according to the contract - Service level agreements (SLAs) were properly calculated and reported.	- Proposals sent to the customer without all required approvals and not in accordance with IBM guidelines. - Proposals or contracts which are not in compliance with the customer requirements or are associated with high risks and/or difficulties that pose a challenge when executing process delivery. - Inadequate project execution in conjunction with lack of monitoring of service delivery could result in inconsistent delivery, financial loss and customer dissatisfaction. - Failure to properly identify and track risks could lead to customer dissatisfaction or inefficient allocation of project resources and negatively impact IBM's image or the financial performance of the contract.

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Concern
Labor Claiming A list of employees and contractors who claimed hours in the Intranet Labor Claiming Tool (ILC) for the projects and attendance or leave records.	Duplicate hour claiming; hours claimed while on vacation; hours claimed or adjusted for nonexistent or separated employees; excessive labor hours	• Inaccurate and unauthorized hours charged could lead to inaccurate financial recording, customer dissatisfaction, and legal issues. • Excessive labor hours could lead to regulatory non-compliance or employee dissatisfaction.
Procurement • Universe of all purchase order (PO) and non-PO transactions during the audit period • Universe of all invoices paid during the audit period • Universe of all bypasses identified during the audit period	Review transactions and payment data: • Review invoices with POs or non-POs raised close to or after invoice dates. Review report of bypasses committed and identify repeat offenders: Assess the actions taken by management to address repeat offenders	• Lack of procurement involvement may result in increased costs to IBM and indicate instances where "arm's length" relationships are not in place. • Continued bypass activity may indicate lack of monitoring of cost or expense spending. • Where reliance is placed on third parties for the delivery of services, IBM may not have adequate contractual cover in situations where contracts are not in place on a continued basis. • Unidentified bypass offenders may result in further bypasses.

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

PLANNING: Self-Service Report

Some information previously included in the Initial Data Request (IDR) items which continue to be relevant information in audits will now be extracted directly by the audit team. These are as follows:

Information previously in IDR	Instructional materials to download information
• Management Self-Assessment of Controls (MSAC) • Risk Evaluations (RE's) • Proactive Business Control Reviews • (No key controls)	Login to OpenPages Risk, Controls and Assurance . Open User menu in top right, select Finance Business Controls (FBC) General User as profile, Open Primary menu in top left, select the applicable criteria to get the results.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

PLANNING: Reference Material

Corporate Documents

- [IBM Business Conduct Guidelines \(BCG\): https://w3.ibm.com/ibm/corporate-documents/business-conduct-guidelines](https://w3.ibm.com/ibm/corporate-documents/business-conduct-guidelines)
- Corporate Policy 127: IBM's Culture of Health and Safety <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-127>

Corporate Instructions

- CIO 162 Financially Significant and Other Enterprise Applications <https://w3.ibm.com/ibm/corporate-documents/cio/cio-162>
- FIN 101 Control of Disbursements: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-101>
- FIN 122 Requirements for the Timely Integration of IBM wholly- owned and majority-owned entities: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-122>
- FIN 151 Application Systems Control and Auditability (ASCA) <https://w3.ibm.com/ibm/corporate-documents/fin/fin-151>
- FIN 168/LEG 168 Business Amenities and Gifts: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-168-leg-168>
- FIN 178 Highly Protected Risks <https://w3.ibm.com/ibm/corporate-documents/fin/fin-178>
- FIN 181 Bank Account Management: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-181>
- FIN 182 Management Self-Assessment of Control: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-182>
- FIN 183 Separation of Duties (SOD): <https://w3.ibm.com/ibm/corporate-documents/fin/fin-183>
- FIN 185 Formation and maintenance of legal entities: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-185>
- PROC167 Vendor Sourced Labor Services: <https://w3.ibm.com/ibm/corporate-documents/proc/proc-167>

Corporate Organizational Letters (COL): <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters>

- COL 109 Delegation of Authority - Pricing of Products and Services: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters/col-109>
- COL 111 Delegation of Authority - Real Estate: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters/col-111>
- COL 125 Delegation of Authority - Terms and conditions of contracts for products and services: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters/col-125>
- COL 131 Delegation of Authority – Procurement: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters/col-131>

General Data Protection Regulation (GDPR)

- GDPR Readiness: <https://www.ibm.com/data-responsibility/gdpr/#4>
- Data Privacy/Protection, Regulations, and Compliance: <https://w3.ibm.com/w3publisher/dprc>
- Privacy Impact Assessment (PIA) <https://w3.ibm.com/ibm/privacy/tools-services/igms#pia>

Other useful links

- Senior Leaders by Functions: <https://w3.ibm.com/w3publisher/corpdev/fin122-page/gpo-ma-leaders>
- Legal Information System - International Transactions - Intercompany Agreements: <https://w3.ibm.com/w3publisher/ica-bratislava/our-instructions/ica-guidance>
- Accounting Policy and Financial Reporting: <https://w3.ibm.com/w3publisher/accounting-policy-financial-reporting>
- Services Accounting Instructions: <https://w3.ibm.com/w3publisher/accounting-policy-financial-reporting/accounting-instructions>
- IBM Safety Standards: <https://w3.ibm.com/w3publisher/ibm-global-safety/safety-standards>
- Compliance with Transportation, Entertainment, and Business Amenities (CTEBA): <https://w3.ibm.com/w3publisher/cteba>

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

PLANNING: Reference Material (continued)

- Information Technology Security Standards (ITSS): <https://pages.github.ibm.com/ciso-psg/main/standards/itss.html#31-general-user-responsibilities>
- Denied Parties List (DPL) and Unauthorized Supplier List (USL): <https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/dpl-and-usl>
- IBM Corporate Security Policy (ICSP): <https://w3.ibm.com/w3publisher/icsp/ibm-corporate-security-policy>
- IBM Procurement Blue Book: <https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/blue-book>

**ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00**

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and results in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Falsified or inappropriate employee expense submission	Review Global Expense Monitoring Compliance and Analysis Program (GEMCAP) reports, look for manager approval and actions according to GEMCAP requirements.	Test for approval of exceptions, verify that exceptions were tracked and monitored, and actions were taken on offenders.
Labor Claiming	Claimed hours should be aligned with local requirements and regulations, exceptions should be approved and documented.	Labor Claiming testing. Overtime/vacation and leave of absence (LOA) testing. If guidelines are not followed, test if risks were assessed, the result was documented and approved by management. Testing should be addressed to management awareness on assumed risks. Test for total hours claimed. Test for correct validation at project level.
Misrepresentation	Information must be valid and accurate. Tracking of integration plans.	This is an attribute in many tests, the auditor verifies if the supporting documentation is valid, accurate, opportune, and approved/reviewed by manager. Use of available analytics tools. Review if information related to integration plans is accurate and has been reported and approved consistently. If milestones were missed, ensure they are reported to management.
Unapproved Pricing Commitments (UPC)	Last approval for business case, focus on pricing case. Analyze repetitive offenders.	Determine if the proposal/offering has been internally approved before being sent to the customer, including changes to previously approved cases. Focus also on special bid offerings and transaction agreements for applicable entity. Test if repetitive offenders showed a pattern or trend (same customer, same type of error, etc.)

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

PLANNING: Fraud Template (Continued)

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Conflict of interest	Activities performed by employees should be assessed by management to detect possible conflicts of interest.	Risks related to separation of duties (SOD) have been periodically (at least annually) assessed and documented by management. If conflicts were identified, actions were properly taken to mitigate.
Falsification of records/documents	Documentation accuracy.	Supporting documentation should be valid, accurate, and approved at the time of the transaction posting. There should not be inconsistencies on chronology and types of letters.
Exposure of IBM and customer/supplier's information to unauthorized access	Information was timely and correctly classified and protected as designed.	There are several tests in this area, for physical as well as internet data, workplace security, device security, encryption, access management, and control access systems testing.
Use of unapproved systems/processes	The use of non-IBM legacy systems and tools has been approved by management, and controls were implemented to mitigate risks.	When non-IBM legacy systems are in place, conflict of interest testing should be done, as well as a review of documented discussions with owner organizations to understand how risks were mitigated, test accordingly. System inventories should be in place and should coincide with reporting of non-legacy systems and applications to IBM Chief Information Office (CIO).

Note: The probability and impact will vary depending on the entity that is being audited.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Data Privacy and Protection

Objective:

To verify that access to systems used in the delivery of services to customers is appropriately controlled, provisioned, and deprovisioned in a timely manner to prevent unauthorized access to applications and sensitive information. Access must be granted based on a valid business need and supported by documented management approval. The review will also ensure that the entity adhere to IBM's ITSS, including compliance with Chapter 3: End User Acceptable Use Requirements, specifically Section 3.1 – General User Responsibilities.

To assess whether the location is structured and operated in a manner that ensures appropriate separation of duties (SOD), thereby reducing the risk of conflicts of interest and unauthorized activity. The review will also evaluate the effectiveness of access controls in preventing unauthorized access to systems, applications, and sensitive information.

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Risk/Exposure:

Acquired and Retained Entities that are not fully aligned with IBM's security standards and governance framework may present elevated risks to both IBM and its customers. Key risks include:

- Unauthorized access and data manipulation
- Customer dissatisfaction
- Financial loss
- Legal disputes

Note: During an integrated audit, refer to IT audit program for data privacy and security audit protocols and risk area evaluation.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Data Privacy and Protection

Primary Test: Data Security and Privacy (DP001.P)

Objective:

To assess whether the entity had implemented effective controls over applications, databases, and data used in the delivery of services to customers.

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Approach:

Verify compliance with IBM's internal standards, such as ASCA certification requirements, and ensure alignment with customer contracts and data protection obligations. Oversight from the GPO is essential to ensure consistency and integration readiness across all entities.

Application and Database Review

Inventory Validation: Review the list applications, spreadsheets, desktop automation, and robotic process automation (RPA) ecosystem used. Review and verify the FIN151 (ASCA) applicability assessment of all applications and spreadsheets managed by the entity.

Access Control Evaluation

- Access Justification: Review access control lists for the entity's applications and systems to ensure that access is granted based on a documented and valid business rationale.
- Continued Business Need (CBN): Verify that periodic reviews of access were conducted to confirm continued business need, and that these reviews are complete and properly documented.
- Authorization and deprovisioning: Confirm that access approvals were authorized by appropriate management and that access was promptly removed when no longer justified.
- Security Controls: Evaluate whether physical and logical security controls were in place for systems used in service delivery, and that these controls met IBM and customer contractual requirements.
- Customer Application Access: Review the employee's access to customer applications to ensure that the entity has received appropriate approval from the customer and, if applicable, from the application licensor.

Data Privacy and Protection

- Customer data privacy requirements: Review the customer's definition of data privacy and associated documentation requirements. Validate that the entity has implemented controls to protect the customer and end-user information in accordance with these requirements.
- Information Classification: Confirm that documentation was properly classified according to the customer guidelines. Ensure that controls were in place to support the classification and protection of the customer's confidential information, as defined in the signed contract.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Data Privacy and Protection

Primary Test: Data Security and Privacy (DP001.P) (continued)

The Global Privacy Control Assessment Questions are composed of two key areas to help address compliance with these various high-level laws.

- **The entity as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that the entity must meet when acting as a Controller of Personal Information (PI). That is, PI that the entity collects and processes for its own purposes, such as Business Contact Information that the entity holds on its existing or potential customers or suppliers.
- **The entity as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that the entity must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that the entity provides to Clients, regardless of whether the entity develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Determine if the entity is a Controller or Processor of PI or sensitive personal information (SPI) data in the process based on the responses provided from the Initial Data Request.

Testing:

The entity as Controller

If the entity is Controller, request a risk-based sample of PIA for the processes and/or assets. Complete the testing based on the latest CA&AS required data privacy education.

The entity as Processor

If the entity is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing based on the latest CA&AS required data privacy education.

The entity as both Controller and Processor

Test either the entity as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Data Privacy and Protection

Primary Test: Separation of Duties (DP002.P)

Objective:

To determine whether individuals within the entity hold incompatible responsibilities that could compromise the integrity of the internal control environment. To assess whether appropriate separation of duties (SOD) exists to prevent any single individual from having the ability to initiate, authorize, and modify transactions or data without oversight. Additionally, to evaluate whether access to critical systems and data—particularly the ability to add, change, or delete information—is strictly controlled, appropriately restricted, and supported by documented management approval.

Approach:

- Request a current organizational chart of the entity detailing employee roles and responsibilities to identify potential separation of duties exposures.
- Examine access control listings and critical transaction workflows to ensure that duties were appropriately segregated, and access was properly authorized.
- Obtain and review the entity's formal SOD assessment to identify any role conflicts or control gaps.
- Review application system mnemonics and transaction capabilities to identify transaction conflicts (for example, billing, accounts receivable (A/R), customer records, inventory, and accounting). If conflicts have been identified or existed, review the design and execution of secondary controls to ensure they were sufficient to mitigate risks. In addition, consider further testing of transactions processed by the individuals with conflicts.

Some common conflicts to test (roles and responsibilities)

- Employees with billing capability should not have:
 - A/R processing or adjustment of billing that they generated
 - Access to customer number processing
- Employees with cash application capability should not have:
 - Capability to process bank adjustments, create billing, issue credits or change or create customer master records
 - Responsibility to reconcile bank accounts
 - Access to unendorsed checks
 - Accounts Payable processing capabilities/responsibilities
 - Access to inventories of blank checks or other invoice documents
- Employees with A/R responsibility should not have:
 - Billing or adjustment processing responsibilities
 - Price override authority
 - Cash application or cash adjustment capability
- Employees with customer master record responsibility should not have:
 - Price override
 - Billing or A/R responsibilities
 - Order entry or management authority
- Employees with supplier master file (name, address, bank account) creation, modification, or deletion responsibilities should not have:
 - Approval, verification, or restoration responsibilities
 - Purchase order entry
 - Invoice submission
 - Payment processing
- Employees with control over financial stationery (such as: order cash receipt books or blank invoices) should not have:
 - disbursement control responsibilities

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Financial Management

Objective:

To assess the effectiveness of controls over financial recording and reporting, contract performance monitoring, and bank account management in accordance with the internal guidelines and external regulations

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Risk/Exposure:

Inaccurate cost and revenue reporting could have a significant impact upon the integrity of the IBM financial statements, delayed cash flow, unapproved loss of profitability, and customer dissatisfaction. Insufficient controls over contract performance monitoring and bank account management could lead to operational inefficiencies, unauthorized activities, and financial loss.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Financial Management

Primary Test: Revenue Recognition (FM001.P)

Objective:

To evaluate the effectiveness of the general ledger (GL) process, focusing on the accurate and timely posting of financial transactions from subsidiary or auxiliary ledgers into the main ledger accounts, as well as the creation of accounting entries based on internal ledger tables. To ensure compliance with Generally Accepted Accounting Principles (GAAP) and adherence to robust internal controls, particularly within Acquired and Retained Entities environments.

Given the risks of inconsistent application of accounting principles, weak or undocumented control environments, and delayed or inaccurate financial reporting, auditors must assess the alignment with IBM's mandatory requirements and standard practices and the presence of compensating controls.

Approach:

Reconciliation Review:

- Is there a structured process to match individual cost and revenue transactions within the entity? Were there any aged or unmatched items identified during reconciliation, and what were the root cause and the mitigation action?
- Obtain and review the revenue recognition report and reconcile the reported revenue with the general ledger and financial statements to confirm completeness and accuracy.

Exception Analysis:

- Were there instances of revenue recorded without corresponding costs (or vice versa) within the entity? Were transactions posted to incorrect accounts or periods identified, and what measures were in place to prevent such errors? Were there manual adjustments without adequate documentation or approval, and how were these instances addressed?
- Analyze accounting entries and focus on entries with risks of manipulation or error, such as:
 - Software revenue recognition that may be fixed irrespective of contract terms or location.
 - Manual adjustments to revenue entries without sufficient documentation or approval.
- Prioritize testing of revenue transactions that carry higher risk, including:
 - Fixed-price contracts (complex revenue recognition, timing, and performance obligations)
 - Manual entries and adjustments (adequacy of controls)
 - Revenue reversals or revenue recognized based on triggers or input from groups outside the accounting function. Verify the accuracy and appropriateness of related commission and incentive payments.
 - Volume-based revenue components (fluctuations in delivery volumes) could impact accuracy
 - Contracts with variable billing terms (more susceptible to misstatement or inconsistent application of accounting policies).
 - Entries processed at quarter-ends or year-end with high value (especially manual entries.)
 - Where revenue is based on labor recording, assess whether any reversals were made post-recording. Evaluate the risk of labor manipulation.

System Integrity:

- Where automated systems were used, how reliable were the data interfaces between billing, inventory, and general ledger systems within the entity?
- Were these systems integrated with IBM's financial infrastructure, or were compensating controls in place to ensure data accuracy and integrity?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Financial Management

Primary Test: Revenue Recognition (FM001.P) (Continued)

Control Environment Assessment:

- Were there adequate controls in place to prevent and detect unauthorized or improper general ledger entries within the entity?
- How effective were these controls in mitigating risks associated with incomplete or delayed transaction postings, administrative inefficiencies, or control breakdowns?

GAAP Compliance:

- Were financial transactions and accounting entries consistently applied in accordance with GAAP within the entity?
- How were potential deviations from GAAP identified, investigated, and rectified within the entity?

Internal Control Documentation:

- Were internal controls related to the general ledger process within the entity well-documented, and were they regularly reviewed and updated?
- How were control failures or gaps identified, investigated, and addressed within the entity?

Period-End Reconciliation and Reporting:

- Were general ledger accounts reconciled accurately and timely?
- How were discrepancies identified, investigated, and resolved during period-end reconciliation reporting?

Journal Entry Approval Processes:

- Were journal entries within the entity properly approved according to established policies and procedures?
- How were unauthorized or improperly approved journal entries identified, investigated, and rectified within the entity?

Other income and/or other charges

- Determine how the entity recorded other income and/or charges in the general ledger. Query the general ledger to verify their recordings were timely and properly accounted for.
- Were there any instances where contract costs were included in other charges?

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Financial Management

Primary Test: Contract Performance (FM002.P)

Objective:

To assess the effectiveness of contract performance monitoring and financial reporting within the entity, ensuring contract financials, including budgets/forecasts, were accurate and adherent to IBM's financial management practices. Focus on evaluating the adequacy of local controls, the reliability of financial data, and compliance with IBM's governance framework. The audit aims to identify and address any risks of financial misstatements, operational inefficiencies, and compliance gaps unique to the entity.

Approach:

Forecasting and Reporting

- Review the process for accurate forecasting and tracking from pricing case to actuals. Were adjustments to the base pricing case, such as: additional/reduced resource charges (ARCs/RRCs), contract changes (CCs), and request for services (RFS), made on a timely basis to enable a like-for-like comparison between pricing case and actuals to be maintained?
- Verify delivery issues were accurately and timely reflected, especially for revenue recognition under percentage-of-completion method. If not, assess the cost and gross profit (GP) impacts.
- Assess whether effective interlocks with the finance team were in place to enable changes in the forecast to be quantified accurately and timely.

Project Control / Analysis

- Was there a process which would highlight projects did not report results within expected financial returns (pricing case or revised forecast)? Were all contracts included? Was such an analysis at the project or contract level?
- Consider GP over- and under-performance when compared with typical GPs or the pricing case. Was root cause of issues properly identified with mitigation actions properly taken?
- Was a periodic review of troubled projects implemented? Were recovery plans including deliverables, milestones, and measurements properly developed and met?
- For contracts involving work-at-risk, verify revenue was recognized upon contract signing.

Capital Allocations

- Was capital expenditure required by contractual deliverables properly planned, requested, and approved? Is this process documented and followed consistently within the entity?
- Was the capital planning aligned with contractual obligations and delivery timelines? Were deviations identified, investigated, and addressed in a timely manner?

Claims and Claims Avoidance

- Were any services or costs being excluded from customer billing despite being contractually required, and were appropriate approvals obtained for any concessions?
- Should concessions made during contract negotiations have been treated as formal claims, and were these concessions appropriately documented and monitored?
- Were concessions promised to customers prior to receiving approvals?
- Was the root cause analysis conducted for any lost revenue due to unbilled services or concessions?

Primary Tax Homes (U.S. Only):

- Was there an approval process for long-term accommodation, including apartments and extended hotel stays, well-defined and followed within the entity?
- Were employees receiving housing-related reimbursements guide on primary tax home requirements, and were controls in place to ensure compliance with these guidelines within the entity?
- Was employee adherence to tax home policies validated through testing, and were reimbursements discontinued and financial reporting corrected for non-compliant cases within the entity?
- Have inappropriate remote living expense reimbursements been avoided, ensuring that they were not billed to customers and impacting financial statements within the entity?

Original Equipment Manufacturer (OEM) Content and Gross versus Net (GvN) Revenue:

- For significant OEM components, assess whether revenue was recorded on a GvN basis.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Financial Management

Primary Test: Bank Account Management (FM003.P)

Objective:

To validate if adequate controls for opening, closing, and maintaining bank accounts were in place and in line with the Corporate Instruction FIN 181.

If the audit entity is an acquired entity, validate that IBM took possession over all the bank accounts within the integration required timeline (also IC001.P).

Bank Account Management is a power reserved to Treasury (refer to FIN 181) to initiate bank account opening, closing, updating, ownership changes, signatory additions/deletions, bank services, fees, and documentation. Only Treasury determines the strategy and structure of bank relationships and setup.

Risk/Exposure:

Undocumented bank relations, bank accounts opened/closed without the required approvals or bank account not established in the ledger could result in improper activities and unauthorized or fraudulent transactions. Not reviewing purpose and/or benefit of each account on an ongoing basis could result in excessive operational and financial cost due to bank relationships/accounts not needed.

Inadequate management of acquired entity banking relationships and access to the bank accounts could result in unauthorized activities and financial loss.

Approach:

- Request a list of bank accounts that were ever active during the audit period for the entity.
 - Include the bank name, bank account details and purposes, and ledger account details.
 - Validate if appropriate actions were taken by the bank account owner
 - To ensure that only authorized personnel may disburse funds or have signature authority to amend banking terms and conditions on IBM bank accounts
 - To ensure that activity in the bank account and account balance are monitored
 - To ensure that Accounting has access to bank account statements
- Request all limits assigned to the banks, including the changes. Were counterparties approved and selected in accordance with established risk guidelines?
- For an acquired entity, validate if CBI tasks were completed within the required integration timeline.
 - Treasury is responsible for sending a letter to all known banks and request positive confirmation of all accounts within 30 days of ToC.
 - Ensure that counterparty limits were assigned up to 10 working days post the integration.
 - Review the authorized signatories and ensure that IBM finance managers were added as authorized signatories.
 - Request evidence that IBM took possession of all manual payments and bank seals.
 - Was there proper monitoring to perform counterparty limits?
- Request a list of changes in authorized signatories during the audit period. Select a sample of banks and verify that the bank was notified timely about the changes.

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Local Regulation and Oversight

Objective:

To assess internal controls and processes designed to maintain compliance with IBM's objectives and regulatory requirements and ensure adherence to IBM corporate policies for involvement with government officials, lobby regulations, contracted services and vendor activities, and the communication of regulatory changes to appropriate parties.

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Risk/Exposure:

Non-compliance with local laws and regulations could lead to legal penalties, reputational harm, financial losses, and operational disruptions. Inadequate internal controls and processes may cause undetected compliance issues, deviations, and non-compliance.

Unauthorized or unapproved involvement with government officials, including the use of third parties to act on behalf of IBM, could result in fines, penalties, and damage IBM's reputation.

Inaccurate reporting or registration of lobbying activities could result in fines, penalties, and damage IBM's reputation.

Lack of controls over the selection and management of third parties could result in litigation against or a financial loss to IBM.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Local Government and Oversight

Primary Test: Local Controls and Regulations (LC001.P)

Objective:

To determine if internal controls and processes were designed to maintain compliance with IBM's objectives and regulatory requirements.

Approach:

- Review documentation and conduct interviews to verify that local tax, labor, data security and protection, environmental, export, health and safety (H&S), and other laws and regulations were thoroughly assessed for compliance.
 - Was there a compliance assessment conducted for local tax, labor, data protection, environmental, export, and H&S laws and regulations?
 - Was there documentation of legal reviews or consultations with local counsel?
 - Were any gaps identified during the assessment? If so, what remediation actions were taken?
 - How was ongoing compliance with local regulations monitored?
- Evaluate the effectiveness of internal controls and processes implemented to maintain compliance in the aforementioned areas, including policies, procedures, and training programs.
 - What internal controls were implemented to ensure compliance in each regulatory area?
 - Were there documented policies and procedures supporting these controls?
 - How were employees trained in these policies?
 - How was the effectiveness of these controls evaluated (e.g., internal audits, control testing)?
- Examine evidence of ongoing monitoring and reporting mechanisms to identify and address any compliance issues or deviations.
 - What systems or tools were used to monitor compliance on an ongoing basis?
 - Were there dashboards or reports that track compliance metrics?
 - How were compliance issues or deviations identified and escalated?
 - Were there examples of recent compliance reports or issue logs?
- Assess the adequacy of management's review and approval processes for compliance-related decisions and actions.
 - What was the process for management review of compliance-related decisions?
 - Were there documented approvals for key compliance actions?
 - How frequently did management review compliance performance?
 - Was there evidence of management intervention in resolving compliance issues?
- Analyze the effectiveness of corrective action plans and their timely implementation to rectify any identified compliance gaps or non-compliance instances.
 - Were corrective action plans documented for identified compliance gaps?
 - Who was responsible for implementing and tracking these plans?
 - What was the typical timeline for resolution?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Local Government and Oversight

Primary Test: Local Controls and Regulations (LC001.P)

(Continued)

- Evaluate the integration of compliance considerations into the entity's strategic planning and risk management processes.
 - a. How were compliance risks incorporated into the entity's strategic planning?
 - b. Was compliance considered in enterprise risk assessments?
 - c. Were there cross-functional teams involved in aligning compliance with business strategy?
 - d. How did the entity prioritize compliance risks?
- Review the entity's commitment to ethical conduct and integrity, as reflected in its code of ethics, whistleblower policies, and other relevant guidelines.
 - a. Was there a formal code of ethics in place?
 - b. How was the code communicated to employees and third parties?
 - c. Were whistleblower policies documented and accessible?
 - d. What mechanisms existed for reporting ethical concerns anonymously?
- Assess the effectiveness of communication and training programs to ensure that employees understand and adhere to compliance requirements.
 - a. What training programs were in place to educate employees on compliance requirements?
 - b. How frequently was training conducted and updated?
 - c. Was training tailored to different roles or risk areas?
 - d. How was training effectiveness measured (e.g., assessments, feedback)?
- Evaluate the entity's responsiveness to changes in local laws and regulations, and its ability to adapt its internal controls and processes accordingly.
 - a. How did the entity stay informed about changes in local laws and regulations?
 - b. What was the process for updating internal controls and policies in response?
 - c. Can you provide examples of recent regulatory changes and how the entity adapted?
 - d. Was there a designated compliance officer or team responsible for monitoring legal updates?
- Examine the entity's approach to managing third-party relationships and ensuring that they comply with relevant laws, regulations, and internal policies.
 - e. What due diligence was performed on third parties before engagement?
 - f. Were third parties required to comply with the entity's policies and applicable laws?
 - g. How was third-party compliance monitored (e.g., audits, certifications)?
 - h. Have any third-party compliance issues been identified and addressed?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Local Government and Oversight

Primary Test: Involvement with Government Officials (LC002.P)

Objective:

To verify adherence to IBM corporate policies for involvement with government officials when advocating IBM's policies with governments.

Approach:

- Validate whether the employee or the third-party acting on behalf of the entity, that interacted with government officials, was authorized and approved to do so, or reviewed for compliance with internal requirements and external regulations? (BCG, Compliance with Transportation, Entertainment, and Business Amenities (CTEBA), and registered lobbyists)
- Review a sample of quarterly lobbying reports to verify accurate and timely communication in line with lobbying regulations. Were the lobbying activities authorized and in compliance with regulations? Were employees engaged in lobbying activities properly registered if required?
- Review transactions and dollars spent on consultants, legal fees, or other contracted services related to policy advocacy and lobbying activities to validate if they were selected using current purchasing guidelines, have documented contracts that define the scope of work and protect IBM's interests, and have not exceeded the maximum length of service.

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Security Access Management

Objective:

To assess whether appropriate access controls were in place to prevent unsecured workspace. To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Note: IBM Security Corporate Policy applies to Acquired and Retained entities which are subject to the IBM BCG.

Risk/Exposure:

Insufficient access management could lead to loss or misuse of intellectual and physical assets or create an insecure work environment for personnel.

Note: During an integrated audit, refer to IT audit program for access management audit protocols and risk area evaluation.

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Access Management

Primary Test: Security Access Management (AM001.P)

Objective:

To determine whether the processes and technology in support of physical access management were operating effectively and in line with the Corporate Security Policy.

Approach:

Review the latest version of the Corporate Security Policy related to Identify and Access Management.

- When the entity shares space with third parties, verify that controls were implemented to limit access from shared space into the entity's internal space.
- Determine if controlled access system (CAS) were issued per requirements, for example:
 - Was documentation of proper authorization for a visitor obtained prior to badge issuance?
 - Was visitor identity validated by a government ID or the person authorizing the visit? (CAS badges for visitors are not allowed unless an exception is granted by Corporate Security Policy and Compliance manager/designee.)
 - Were temporary or contractor badges properly authorized and validated (W3 people records) prior to issuance?
 - Were standard IBM ID badges, except tenant badges, used?
 - Was badge access timely removed for separated employees or lost badge reported?
 - Was the secure area manager's approval obtained prior to authorizing access or application to the secure area?
 - Were daily matches of regular employees performed for strategic CAS access validation?
 - Were monthly (manual) reconciliation of regular employees performed for non-strategic CAS access validation?
 - Was a non-regular employee manager validating access positively every 90 days?
 - Was secure area validation performed periodically as designed?
 - Was tenant access authorization reviewed every 90 days by Global Real Estate manager/focal?
- Determine if CAS were removed per requirements, for example:
 - Was a separated employee's access timely removed (manually within 3 business days from notification or automatically within 24 hours of notification)?
 - Were the CAS/HR database reconciled every 30 days where a manual process was used?
 - Was there daily count/inventory of active temporary CAS badges?
 - Was a lost badge deactivated within 24 hours of notification?
- Conduct on-site inspections to verify that there were risks of loss or misuse of intellectual and physical assets owing to poor security access management.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. FIN 122 Integration Compliance

Objective:

The objective of integration activities in IBM's acquisition process is to seamlessly incorporate the operations of an acquired entity into IBM's business environment. It is desirable that acquired entities are fully integrated into IBM's legal entities, processes, and technology and application stack as quickly as practicable.

The Corporate Instruction Finance 122 (FIN 122) - Requirements for the Timely Integration of IBM wholly-owned and majority-owned entities, effective on January 6, 2026 (new version), sets out guidelines for the timely completion of Transfer of Controls (ToC) and Critical Business Integration (CBI) activities within applicable IBM global processes for the Acquired and Retained Entities. Note that the old FIN 122, which was valid before January 6, 2026, set out guidelines for ToC, the Transfer of Employment (ToE), and the Transfer of Business (ToB), of wholly-owned entities, including acquired entities, that had not integrated into IBM's global processes.

- ToC is effective on the date of acquisition closing, when IBM global process owners (GPOs) assume the decision rights, responsibilities, and accountability for integrating their operations or processes across the Acquired Entities.
- Only for new FIN 122: All Critical Business Integration (CBI) activities shall target completion within their approved timeline phase, but no later than (1) 6 months following the acquisition closing date or (2) the Integration Review Board (IRB)-approved integration date.
 - CBI is an independent milestone for every integration-related global process. It refers to the completion of critical integration tasks for each applicable process, including the assignment and transfer of all Acquired Operations' assets, employees, and business processes to the appropriate IBM entity in compliance with all local legal and regulatory requirements. Each CBI task is assigned to a target timeline phase by the owning GPO Mergers and Acquisitions (M&A) Leader, who is appointed to be accountable for the GPO responsibilities within their functional areas, with support by their Senior Functional Leader.
 - Consistent with the objectives of FIN122, the GPO M&A Leaders are expected to complete CBIs as soon as practicable following closing using a risk-based approach, taking into account the underlying business case for the acquisition.
 - GPO M&A Leaders play a pivotal role in ensuring that CBI tasks within their functional areas are completed on time and confirming such completion in the Integration Management System, specifically DealMobilizer.
- Only for old FIN 122: ToE and ToB shall be completed within the later of 6 months following (1) the ToC or (2) the date of FIN 122.

Note: There are no expectations around business integration for majority-owned entities.

Risk/Exposure:

Deviations from the intended integration level at the time of acquisition or delays in completing CBI activities (new FIN 122)/ToE and ToB (old FIN 122) may expose IBM to financial, security, legal, and reputational risks.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. FIN 122 Integration Compliance

Primary Test: FIN 122 Integration Compliance (IC001.P)

Objective:

To validate compliance with Corporate Instruction FIN 122, which outlines the requirements for the timely integration of IBM wholly-owned (both new and old FIN 122) and majority-owned (new FIN 122) entities.

Approach:

New FIN 122 (effective on January 6, 2026)

- Obtain the Transfer of Controls (ToC) date, which is typically listed in DealSpace and effective on the date of close of the acquisition.
- Examine integration plan and timelines (refer to DealMobilizer Integration Deliveries/Tasks in 2026) to verify that all required Critical Business Integration (CBI) tasks were properly identified and assigned target completion dates within the six-month period or the Integration Review Board (IRB)-approved Business Integration Date (BID).
- Select sample(s) of completed CBI tasks that were confirmed in DealMobilizer within 6 months or the IRB-approved BID to verify that CBI tasks were properly completed, and business integration was confirmed as achieved in DealMobilizer by the global process owner (GPO) mergers and acquisitions (M&A) leader. Verify that a CBI task was not confirmed prematurely to avoid having to request a BID extension.
- Select sample(s) of CBI task(s) that were not completed within 6 months or the IRB-approved to determine if an extension was requested and approved per FIN 122.
- Review approvals for any extensions to the Business Integration Date, ensuring that compelling business justifications and plans were provided and signed off by the required approvers.
- Compare the actual completion dates of CBI tasks against the approved timeline phases (6 months or IRB-approved BID) to determine if any tasks exceeded the specified deadlines without proper justifications and extension approvals.

Old FIN 122

- Review evidence of the declaration of ToB/ToE completion notifications in accordance with FIN 122.
- Assess whether the entity achieved full integration and met all ToE and ToB requirements within the prescribed timeframe. If not, verify that a documented extension or approved exception as below was obtained in accordance with FIN 122.

Extension process:

- Each required approver must explicitly approve in writing, and each approval must be maintained by the submitter/unit making the request.
- An extension to the approved ToE date based solely on local legal or regulatory requirements must be reviewed and approved by:
 - IBM's Senior Vice President (SVP) & Chief Human Resources Officer.
 - IBM Business Unit (BU) SVP; and
 - IBM's Vice President (VP) and Assistant General Counsel, Labor & Employment Law.
- Any other extension to the approved ToE date must have a compelling business justification and plan, approved by:
 - IBM's SVP & Chief Human Resources Officer.
 - IBM BU SVP; and
 - IBM's SVP, Strategy and M&A.
- Any extension to the approved ToB date must have a compelling business justification and plan, approved by:
 - IBM SVP, Strategy and M&A;
 - IBM BU SVP; and
 - IBM VP/Assistant General Counsel for M&A.

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. FIN 122 Integration Compliance

Primary Test: FIN 122 Integration Compliance (IC001.P)

(continued)

Exception Process:

Periodic reviews are required of all Non-Integrated Subsidiaries (NIS) or Acquisitions with exception approvals in place for delayed ToB. Any exception to the declaration of ToE/ToB completion criteria outlined in FIN 122 must be approved by the SVP of Strategy and M&A, after approval of the appropriate senior functional leader or their delegate (e.g. SVP Transformation & Operations, SVP & Chief Human Resources Officer, etc.).

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. FIN 122 Integration Compliance

Primary Test: Integration Plan (IC002.P) (only applicable for old FIN 122)

Objective:

To assess the GPO's execution of post-acquisition management and integration planning for the entity, with a focus on operational readiness and alignment with IBM's integration goals. The objective is to ensure that the acquired entity is effectively incorporated into IBM's processes, systems, and governance framework, with appropriate oversight and risk mitigation.

Approach:

Review the post-management and integration or plan for applicable operational activities. The goals of the integration plan should be understood for the specific auditable unit being reviewed. The goal is to successfully incorporate the acquisition's operations into IBM.

Test the following:

Integration Scope and Coverage

Did the integration plan comprehensively address relevant operational areas, including human resources, finance, legal, marketing, sales, product development, service delivery, manufacturing, distribution, intellectual property, and other key processes? Note: Applicability may vary based on the nature of the acquisition.

Risk and Gap Management

- Were risks and gaps identified during due diligence addressed within the integration plan?
- This process should be managed through IBM's M&A Accelerator or DealMobilizer platforms.

Plan Updates and Recovery Actions

Was the integration plan actively maintained with timely updates, status tracking, and documented recovery actions for missed or at-risk milestone? This should also be managed via M&A Accelerator or DealMobilizer.

GPO/Entity Owner Engagement

Was the GPO appropriately engaged to resolve material issues or obstacles? Confirm that critical controls were established by GPOs and implemented in a timely manner, as applicable.

CIO 162 Compliance

Were required activities under CIO 162 completed? If full compliance is not feasible within the first full quarter post-acquisition, confirm that a CIO 162 risk evaluation or issue has been submitted in FBC OpenPages with the entity Chief Financial Officer (CFO) approval. If integration is not planned, ensure that justification is documented as a NIS Issue in FBC OpenPages, with appropriate approvals and periodic reassessment.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. FIN 122 Integration Compliance

Primary Test: Communication Strategy (IC003.P) (only applicable for old FIN 122)

Objective:

To confirm the existence and effectiveness of a structured process for monitoring and communicating the progress of integration activities to the GPO.

Approach:

To determine if the GPO's integration plan has been effectively communicated to the execution team.
Test the following:

Assessment of Training and Role Clarity

Review the integration plan to evaluate if adequate training was provided to the execution team.

- Was there documentation or evidence of training sessions conducted for the execution team?
- Were roles and responsibilities communicated to team members?
 - Were there role-specific training materials or onboarding guides available?
 - What mechanisms were in place to verify that training was effective (e.g., assessments, feedback surveys)?
- Were key milestones and deliverables clearly defined and understood by all stakeholders?
- How was alignment with the overall integration strategy ensured across different teams?

Evaluation of Communication Mechanisms

Examine the communication framework used to keep the GPO informed of the progress, including

- Reviewing the frequency, format, and content of status updates.
- Assessing the management system or tools used for reporting.
- Determining whether escalation paths and feedback loops were clearly defined and functioning effectively.
 - Was there a consistent frequency and format of status updates provided to the GPO?
 - Were there examples of recent communications or reports shared with the GPO?
 - Were there effective tools or platforms used to manage and report integration progress (e.g., dashboards, project management software)?
 - Were escalation paths documented and understood by the execution team?
 - Was there a structured feedback loop?
 - How was feedback from the GPO incorporated into the integration process?
 - Were there any documented issues with communication delays or breakdowns? If so, how were they resolved?
 - How was communication effectiveness monitored or evaluated?

Verification of GPO Engagement in Oversight Activities

Confirm that there was a documented plan for the GPO's involvement in:

- Performance reviews of the integration process.
- Continuous improvement initiatives.
 - Was there a documented plan outlining the GPO's oversight responsibilities during integration?
 - How frequently did the GPO participate in performance reviews or integration checkpoints?
 - How were continuous improvement initiatives identified and implemented by the GPO?
 - How was compliance monitored, and what is the GPO's role in this?
 - Were there documented examples of the GPO addressing issues or risks during integration?
 - How did the GPO ensure visibility into day-to-day integration activities?
 - What metrics or key performance indicators (KPIs) were used to evaluate integration success, and how was the GPO involved in reviewing them?

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. FIN 122 Integration Compliance

Primary Test: GPO Oversight and Governance to ToB (IC004.P) (only applicable for old FIN 122)

Objective:

To assess the subsidiary's readiness for integration into IBM's corporate environment by evaluating its alignment with GPO oversight and key operational and governance requirements.

Approach:

To evaluate the effectiveness of risk management practices, the integration of IT systems and data security protocols, alignment of governance structures with IBM standards, and the adequacy of monitoring mechanisms for tracking integration progress. Additionally, to confirm the existence of plans for performance evaluation, continuous improvement, and sustained compliance with IBM's strategic requirements.

Test the following:

Risk Management Evaluation

Review the subsidiary's risk management plan to determine its effectiveness in identifying, assessing, and mitigating risks that could impact IBM's operations, reputation, or compliance posture. Assess whether the plan included appropriate controls, escalation procedures, and contingency measures.

- Was there a documented risk management plan specific to the integration process?
- What methodology was used to identify and assess risks (e.g., risk matrix, heat maps)?
- Were risks categorized by impact (e.g., operational, reputational, compliance)?
- What controls were implemented to mitigate identified risks?
- Were escalation procedures clearly defined and tested?
- How often was the risk register updated, and who is responsible for maintaining it?
- Were contingency plans in place for high-impact risks?

IT and Data Integration Review

Examine the processes established for integrating the subsidiary's IT systems, data assets, and security protocols into IBM's corporate infrastructure. Verify that these processes support interoperability, data integrity, and compliance with applicable data protection regulations.

- What systems and platforms were being integrated, and how was compatibility ensured?
- How was data integrity maintained during migration or synchronization?
- Were there documented procedures for mapping and transforming data between systems?
- What security protocols were in place to protect data during and after integration?
- How was compliance with data protection regulations (e.g., GDPR and California Consumer Privacy Act) verified?
- Were access controls and user permissions aligned with IBM's standards?
- Were there any data breaches or integration-related incidents? If so, how were they handled?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. FIN 122 Integration Compliance

Primary Test: GPO Oversight and Governance to ToB (IC004.P) (continued) (only applicable for integration completed before January 6, 2026)

1. Governance Structure Alignment

Evaluate the subsidiary's governance framework to confirm planned adjustments that align with IBM's corporate governance policies and practices. This includes reviewing organizational charts, decision-making authorities, and oversight mechanisms.

- a. Was there a revised organizational chart reflecting post-integration governance?
- b. How were decision-making authorities defined and delegated?
- c. What oversight mechanisms were in place to ensure accountability?
- d. Were governance policies harmonized with IBM's standards (e.g., ethics and compliance)?
- e. How was alignment with IBM's governance structure communicated to the leadership?
- f. Were there any gaps or conflicts between the subsidiary's governance and IBM's policies?

2. Monitoring and Compliance Oversight

Verify the existence of a structured process for tracking integration progress and ensuring compliance with IBM's strategic objectives and regulatory requirements. Assess the use of dashboards, reporting tools, and periodic reviews to monitor KPIs.

- a. What tools or dashboards were used to monitor integration progress?
- b. Were KPIs defined and tracked regularly?
- c. How frequently were integration status reports generated and reviewed?
- d. Who was responsible for compliance oversight during integration?
- e. Were there documented procedures for identifying and resolving non-compliance?
- f. How was the progress communicated to IBM leadership and stakeholders?

3. Performance and Continuous Improvement Planning

Confirm that the subsidiary has a documented plan for conducting performance reviews, initiating continuous improvement efforts, and maintaining ongoing compliance. Evaluate whether these plans include measurable goals, feedback mechanisms, and accountability structures.

- a. Was there a documented plan for conducting performance reviews post-integration?
- b. What metrics were used to evaluate integration success and operational performance?
- c. How were continuous improvement initiatives identified and prioritized?
- d. Were feedback mechanisms in place to capture lessons learned and stakeholder input?
- e. Who was accountable for implementing improvement actions?
- f. How was ongoing compliance maintained and monitored beyond initial integration?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Human Resources (HR)

Objective:

To verify if payroll and benefits eligibility validation (employment periods, and additions/deletions for regular, non-regular, and inactive employees) and payments (including benefits, additional compensation, deductions, and separations) were processed accurately and timely with sufficient approvals and documentation, and recoveries were processed appropriately.

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Risk/Exposure:

Inadequate controls may result in invalid payments, litigation/ arbitration, unauthorized deductions, financial loss, and employee dissatisfaction.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Human Resources (HR)

Primary Test: Payroll (HR001.P)

Objective:

If the entity has its own payroll process different from IBM standards, to test the effectiveness of the payroll design and execution process and to verify appropriate GPO oversight to ensure that deviations from IBM processes were identified, assessed, and managed.

Risk/Exposure:

Inaccurate payments may lead to disputes, financial loss, regulatory non-compliance and employee dissatisfaction.

Approach:

- Identify and investigate exceptions within the payroll process. Were reasons for exceptions documented and visible to and approved by management?
 - mismatches between payroll and employee master file
 - payments to employees not on the employee master file
 - duplicate social security numbers, government identifier numbers, or bank account numbers
 - duplicate names with different social security numbers, government identifier numbers, or bank account numbers
 - bank account blank and net pay not equal to zero
 - payroll and personnel salary rates/bonus not equal or other compensation that was not according to approved rates e.g., overtime, holiday, and shift rates.
 - if someone went from non-exempt to exempt – eligibility
 - payments to non-employee beneficiaries (widows, orphans, incapacitated, and students).
 - different Talent IDs with the same bank account
- Determine the universe of employee payments by type of employee (regular, temp, fixed-term contract, etc.) and by type of benefit (insurance, vacation, holidays, car allowance, etc.) and additional compensation (overtime, shift premium, mileage, etc.)
- Randomly select new employees and the longest-term employees, in proportion with the universe for employee types, benefits and additional compensation.
- Validate the employees and associated payments and deductions using the following suggested
 - employee can be verified through confirmation of second line manager.
 - start date and salary/pay rate match the system and are accurate, documented, and approved.
 - last salary change was properly approved.
 - unpaid leaves of absence were properly deducted.
 - hours paid were properly supported and approved, and within established guidelines.
 - additions and updates to employee files were independently reviewed.
 - payslip accuracy, eligibility, payment accuracy, supporting evidence, and proper review/approval.
- Test the reasonableness of overtime and shift premium payments. Were these properly approved? Did the overtime and shift premiums comply with local regulations, for example length of workday or week? Cross-check sampled payments to identify any payments made to ineligible employees, such as separated or retired employees who were no longer working for the entity.
- Select the highest gross paid regular and non-regular employees and test.
 - the employee was bona fide
 - compensation was valid
 - compensation was properly documented
 - compensation was properly approved
- Were recoveries from employees identified and actioned appropriately?
- How did the global process owner and the payroll processing team monitor the effective, accurate, control of payments from inputs through processing to outputs and distribution?
 - recurring payments, such as salary
 - special payments (awards, overtime, shift premium, hiring bonus, incentives, and salary changes)
 - checks, including blanks, returned, voided, and signature plates

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Human Resources (HR)

Primary Test: Compensation (HR002.P)

Objective:

If the entity has compensation policies different from IBM standards, to test the effectiveness of the compensation design and execution process and to verify appropriate GPO oversight to ensure that deviations from IBM processes were identified, assessed, and managed.

Risk/Exposure:

Failure to properly design, administer, and monitor compensation design and execution could result in excess expenditures, disputes, and employee dissatisfaction.

Approach:

- Request information on the timeline and integration status of the acquisition.
- Ask for a listing of the acquired employees including IBM Talent IDs.
- Review the compensation policy different from the IBM standard process.
 - Was there an agreement to move acquired employees to IBM standard compensation program? If so, did this change occur when required? Or was an extension or exception approved?
 - (Design and execution) Were the process requirement communicated with the employees and management?
 - (Design and execution) How were compensation decisions reviewed? Were there clear roles and responsibilities defined in the review process?
 - Were the compensation transactions for the acquired employees administered in accordance with the (non-standard) policy which applied to them?
 - (Tools) Were control reports, error reports, exception reports and reconciliations used in the compensation tool to ensure that all changes were documented, valid, approved, processed in a timely manner, and have appropriate management visibility?
 - (Tools) Determine if controls were effective to prevent and detect improper or incomplete transmissions of data and ensure that all transmissions were controlled to occur on a scheduled basis. Verify that reconciliations were completed timely.
- From a universe of compensation transactions, examine a judgmental sample. Evaluate whether compensation and recognition decisions were made according to the guidance applicable to the compensation policy and were approved by management according to the applicable approvals process before the decisions were executed.
- Choose some samples involving retention payments. Check to see whether repayment agreements were in place. Were conditions met as required? If not, what was the process for capturing repayment?
- Test out of cycle salary increases.
- Select samples with multiple payments to individuals, such as more than one salary increase or multiple awards during the audit period.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Human Resources (HR)

Primary Test: Benefits (HR003.P)

Objective:

If the entity has benefits policies different from IBM standards, to test the effectiveness of the benefits process and execution process and to verify appropriate GPO oversight to ensure that deviations from IBM processes were identified, assessed, and managed.

Risk/Exposure:

In general, health benefits and life insurance are the most significant benefit programs in terms of costs and potential risks; however, the risks differ depending on the funding of these programs.

Failure to properly design, administer, and monitor benefits design and execution could result in regulatory non-compliance, excess expenditures, disputes, and employee dissatisfaction.

Approach:

Eligibility Determination and Validation

- Review the participant eligibility rules for employees with different employment statuses (e.g., on a paid / unpaid leave of absence, recently separated).
- Reconcile the list of participants in the benefit program and that provided to the Program Administrator (PA). If there are discrepancies, can they be explained?
- Request a list of employees of different employment statuses and reconcile it with the list of participants at the PA. Were status updates been properly communicated to prevent invalid claims? How adequate and prompt were retroactive changes handled?

Contribution Collection and Remittance

Determine whether employee contributions (where applicable) were correctly withheld (collected) from employees. Determine whether both employee and employer contributions were correctly remitted to vendors for the payment of premiums and/or administration fees.

- For any employee contribution, review the process for ensuring accurate contributions. Determine whether contributions were correctly paid to eligible participants and/or their dependents.
- Determine how adequate and prompt employee contribution amount changes were handled.
- Review the overall process for collecting employee contributions. Find out what laws or regulations may be applicable to collecting contributions. Evaluate whether these laws and regulations were followed as required and assess the monitoring. Determine whether contributions were promptly collected. Identify whether contributions were taxable and correctly implemented.
- For fully insured plans, trace the flow of funds from contribution determination/collection from employees through to payment of premiums to the vendor. Were both employee and employer contributions reconciled with the premium payments? Were they processed correctly and timely?

Claims processing (for self-insured plans)

- Review the processes for determining whether claims were valid and correct, including claim eligibility, the service provided, and the expense covered by the benefit program. Understand how deductibles, co-payments, and co-insurance were considered when determining the amount of reimbursement for claims.
- Determine how adequate and prompt were covered services, claims, and retroactive changes handled. Were taxes paid correctly when due?
- Evaluate whether these laws and regulations were followed as required and assess the monitoring.
- Test the process for handling and resolving aged claims and write-offs.
- Determine how overpayments were identified, reported, and handled. If overpayments did occur, how adequate was the process to recover the money or proceed write-offs?
- Review the process for communicating and resolving appeals of denied claims. Countries may have laws or regulations requiring fairness and a means for appeal if claims are denied. How clear were the communications about how a claimant could file and escalate appeals of claims that were denied? Evaluate the adequacy of aging and reporting of appeals of denied claims.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Human Resources (HR)

Primary Test: Pension Benefits (HR004.P)

Objective:

If the entity has pension benefits policies different from IBM standards, to test the effectiveness of the pension benefits process and execution process and to verify appropriate GPO oversight to ensure that deviations from IBM processes were identified, assessed, and managed.

Risk/Exposure:

Regulatory non-compliance, excess expenditures, disputes, and employee dissatisfaction.

Approach:

Eligibility

- Obtain a listing of all current recipients for the audit time period. Select a sample of recipients, including each type of recipient in the sample, and test the following:
 - All current benefit recipients are valid current, former employees entitled to payments. For other recipients, confirm valid relationships and entitlement to payment based on the required documentation by the plan or by the local law to prove eligibility.
 - Do duplicate or nonexistent social security records (or equivalent) exist? Were there preventative or detective testing performed for incorrect or fraudulent records?
- Obtain a listing of all separations that occurred over the audit period that includes all relevant service dates to the pension plan. Select a sample of recipients and test for the following:
 - For eligible employees, validate that the required pension benefit was completed.
 - For eligible employees with benefit payouts deferred until a future date, validate that the deferred employees were tracked and managed until the benefits were owed and paid.

Benefit Calculations and Payments Testing

- Verify the accuracy of the benefit calculations (employee data, election, plan, and actuarial input).
- Determine whether country laws regulate a cap for the total pension benefits payments. Test to ensure no one exceeded the limit. Also, review laws for required minimum payments based on age.
- Check salary history against payment terms and conditions (T&Cs) based on retirement date and applicable program.
 - If applicable, have cost of living adjustments been correctly reflected in the payment system?
 - Validate all required approvals were complete for all final calculations, including business as usual (BAU), manual calculations, and lump sums over the clip levels.
 - Were payments made timely and approved by the plan delegations for withdrawals?
 - Verify and validate the process in place to identify and track incorrect payments.
- Review the process for communicating and resolving any appeals for payout calculations. How clear were the communications for how a claimant could file and escalate their appeals if they were disputing the payout calculation? Evaluate the adequacy of aging and reporting.

Contributions and Matching

- For company contributions, review the entity's contribution/matching rules and process used and test:
 - Was the participant eligible? Was the correct percentage matched based on the plan?
 - Was the correct contribution amount made according to the plan guidelines?
 - If an employee was separated, how to ensure contributions were promptly stopped? How would the funds be returned to the company if there was a timing or vesting issue?
- For employee contributions, review the contribution rules and process used and test:
 - How were ineligible employees prevented from making contributions?
 - How was eligibility determined? How were employees notified?
 - If the country requires participation, how to ensure all eligible employees are participating?
 - If there were limits to employee contributions, how were those tracked and managed?
 - How were employee contribution election requests entered and reconciled with the actual?
 - Were employee contribution changes handled in a timely manner?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Human Resources (HR)

Primary Test: Pension (HR004.P)

(continued)

Asset Valuation

- Review the process for valuing a participants' account. Determine the controls in place for flowing contributions into a participants' selected funds. Review the process for assigning the fund's gain/losses and application of the fund's Net Asset Valuation (NAV) for unit determination.
- Determine if a process was in place to periodically review and validate the plan participants' account valuations? Was management knowledgeable of the valuation process?
- Select samples at the employee level from Custodian/ Record keeper to assess the asset values are accurate for each employee record.
 - Assess if the total assets were assigned to the fund correctly based on the investment.
 - Verify employee and employer contribution amounts were accurate within their funds.
 - Validate if the unit value assigned to the fund was accurate and based on the fund NAV.
 - Validate if the unit purchase price and number of units purchased were accurate at the participant level.
 - Check if the sum of participant account values equals the total fund value.

Employee Rollovers in or out of the Fund

- Obtain a list of all employee rollovers in or out of the fund and test for the following:
 - Transfer Out
 - Was there written evidence (letter) of amount rolled over from the entity to the new employer?
 - Was the amount transferred to the new employer correct?
 - Was the employee account at the entity closed in a timely manner?
 - Was there evidence that amount was disbursed to the new employer?
 - Transfers In
 - Was there written evidence of amount rolled over to the entity from the former employer?
 - Was there evidence that the amount was received by the entity?
 - Can it be demonstrated that a new account was opened for the new employee with an amount equal to transfer value?

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Human Resources (HR)

Primary Test: Employee Reimbursements (HR005.P)

Objective:

If the entity has employee reimbursement policies or tools different from IBM standards, to test the effectiveness of the employee reimbursement process and execution and to verify appropriate GPO oversight to ensure that deviations from IBM processes were identified, assessed, and managed.

Risk/Exposure:

Inappropriate or excessive expenses or taxation; non-compliance with internal policies or external regulations.

Approach:

- Review the employee reimbursement process and use reports or listings to select samples that may pose significant risks to the process, e.g., reimbursements that require supporting documentation, require taxation, or high dollars / high volumes. Verify if employee reimbursements were legitimate, justified, supported with valid receipts and required approvals, and in compliance with guidelines. Anomalies were identified timely and effectively.
 - Did automated or operational activity occur? Were the criteria rigorously followed? Was the design of the automated and operational activity effective to mitigate the risk of improper supporting documentation, incorrectly taxed reimbursements, or duplicate payments?
 - Were gifts processed per reimbursement guidelines?
 - For hardcopy forms, was any initial expense report form cancelled or rejected from the system before processing the hardcopy form, if applicable? Was appropriate business justification provided for the reason for the hardcopy form? Were the appropriate approvals in place before releasing the hardcopy form for payment?
 - Were payments correctly applied?
- If advances were processed, were they processed in line with reimbursement guidelines and tracked until repayment?
- Was the expense report released for payment timely per the applicable timeliness and accuracy measurements? If not, was an appropriate analysis performed to identify the reason for the delay and were actions implemented to prevent recurrence?
- For outstanding issues, was there evidence of documentation to identify, track, and follow-up on them until resolution? If not, was an appropriate analysis performed to identify the reason for the lack of resolution and were actions implemented to prevent recurrence?
- Were there duplicate payments monitoring to capture and analyze potential duplicate payments?
- Did the returned payments process ensure accurate and timely repayment to the employee?
- Were employee questions and complaints properly handled?
- Was the taxability of the reimbursement to the employee correctly evaluated and handled?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Product Development and Research Projects

Objective:

To determine whether controls were put in place to ensure that there was an appropriate project management system and that project deliverables were properly executed, tracked, and reported according to the guidelines and agreements.

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Risk/Exposure:

Inadequate controls over product development could lead to legal exposure, unauthorized work initiation, inaccurate product costing, and damage to IBM's image.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Product Development and Research Projects

Primary Test: Product Development (PD001.P)

Objective:

If the entity has its own software product development, to test the effectiveness of project management and delivery processes and to verify appropriate GPO oversight to ensure that deviations from IBM processes were identified, assessed, and managed.

Approach:

- Select a sample of local projects that are part of the overall Offering Management process to determine from documentation, observation, and meetings with project staff.
 - Was an agreement in place before development work started or before its expiration?
 - Were the product release features properly documented and implemented as agreed?
 - Was there sufficient monitoring of the product development to ensure product release was on schedule?
- Methodology/process used by product to execute design, code, build and test and against it, select a sample of projects where:
 - The product releases that were done within the audit period.
 - The entity oversaw the product development of the product releases.
 - The entity oversaw the product testing of the product releases.
- For the selected product development projects, review:
 - The evidence of the requested product release features by the Product Owner/Offering Manager.
 - Evidence of the development monitoring (design and coding) for the above product features.
 - Required quality checks and reviews were completed prior to the software release.
 - Open-source components and third-party intellectual property used had proper attribution or licensing.
 - Security checks were performed prior to sharing any software trial versions to external parties.
 - Any change in the original features.

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Solution Delivery

Objective:

To determine if the solution delivery process encompasses key activities including customer acceptance and fulfillment, subcontractor agreements, billing and accounts receivable, labor claiming, and work at risk.

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Risk/Exposure:

IBM faces significant risks when Acquired and Retained Entities operate outside of its standardized processes and controls, primarily in the areas of contractual and service delivery risks. The lack of robust controls over service contracts can lead to the unauthorized delivery of uncontracted services, unforeseen commitments, and misalignment with customer expectations. These irregularities may result in customer dissatisfaction, reputational damage, and potential financial exposure, thereby eroding client trust and causing revenue loss.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Solution Delivery

Primary Test: Contract Proposal Acceptance and Fulfillment (SD001.P)

Objective:

To verify whether contracts were valid, in accordance with proposals, and in line with the authorized price release. Also, to validate whether the contracts were accurately recorded and maintained during the contract period, systems reflect the correct contractual status, and billable records have been generated on a timely and accurate basis.

Approach:

Conduct reviews with management to understand the contract management process for each type of contract and identify control weaknesses.

Test the following:

- All contractual terms and conditions (T&Cs) offered to the customer were in accordance with the proposal / order, and exceptions were fully approved as defined by COL 125.
 - Non-delegated T&Cs, as defined in COL 125, were not offered in the proposal / contract.
- Determine if the entity has adequate controls over revenue recognition to mitigate the risk of issuing payments based on invalid attainment.
 - Does the entity have a documented firm order and firm order exception policy.
 - A firm customer order / contract has been received (firm order = product/quantity/price/ delivery date/location has been identified).
 - Does a process exist to ensure that the customer has been credit checked and that adequate controls are in place to ensure U.S export regulation compliance?
 - Was the contract price based on pricing delegations, authorized offerings, and justified discounts? Was it sufficiently documented and reflected in the fulfillment system accurately and in a timely manner?
 - Was there evidence that the policy was followed?
 - Verify that the management system includes procedures to assess the incentive payment impact of cancellations, returns, and revenue reversal transactions.
 - Review reports of revenue reversals, firm order exceptions, cancellations after shipment, uninstalled equipment reports, delinquent and deferred accounts receivable, etc. and verify that commissions were not paid for revenue that was reversed or not realized.
- Were services or deliverables rendered after the contract signature? If not, was there approval to proceed in accordance with a defined authority to proceed process?
- Was the system installation date consistent with other installation records (for example, purchase order, contract milestone, and customer acceptance)?
- Were contract amendments justified, approved, and documented before commencement?
- For services contacts, verify:
 - A valid statement of work or type of service being provided was properly documented.
 - Charges were in accordance with planned resources.
 - Percentage of completion documentation was justified.
 - Actual services were recorded and monitored against the plan.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Solution Delivery

Primary Test: Deliverables (SD002.P)

Objective:

To evaluate the effectiveness of governance and control structures in solution delivery to ensure deliverables were on schedule, within budgeted cost, and in accordance with contract requirements.

A deliverable is defined as a physical (including electronic) item required to be provided to the Customer or by the Customer under the terms of a contract. Deliverables may include hardware, software, or reports. Deliverables do not include services.

Approach:

Determine if proper management of deliverables, customer commitments, and financial accuracy are in place. Test the following:

Contract Deliverables:

- Were contract deliverables clearly defined and aligned with the Statement of Work (SoW)?
- Have deliverables been completed within the contractual timelines?
- Were there any documented delays, and if so, what is their impact on the project and customer expectations?
- Did approved deliverables meet the standards specified in the contract?
- Were there any omissions or scope reductions from the original SoW, and what is their business and financial impact?
- Were appropriate controls in place for contract execution and deliverable management?
- Was deliverable quality validated? Were risks of deviations mitigated?
- Was there evidence of issue resolution and control validation related to contract deliverables?

Business Opportunity Complexity and Mandatory Activities:

- Was the complexity of the business opportunity being accurately assessed?
- Were mandatory activities identified based on the Business Transaction Type (BTT)?
- Was the contract reviewed to understand the scope and request a complete inventory of all defined deliverables?
- Were there any missing or unclear deliverables in the contract?
- Were there any potential risks associated with the identified mandatory activities?

Acceptance and Completion Criteria:

- Were customer acceptance criteria and completion requirements clearly defined and documented in the contract?
- Were deliverables confirmed to have met acceptance testing requirements where applicable?
- Were there any discrepancies between the contract and actual deliverables in terms of acceptance criteria?

Root Cause Analysis:

- What were the root causes of unmet deliverables, and how are they categorized (solution design, execution, or delivery)?
- Were there any patterns or recurring issues in unmet deliverables across different projects?
- How were root causes addressed and prevented in future projects?

Concessions and Settlements:

- Were there any concessions, claims, or settlements resulted from delayed, incomplete, or unclear deliverables?
- What was the financial and reputational impact on IBM due to these concessions or settlements?
- Were there any lessons learned from these situations to prevent future occurrences?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Solution Delivery

Primary Test: Deliverables (SD003.P)

(Continued)

Progress Tracking and Risk Management:

- Was progress on deliverables actively tracked? Were risks identified and managed effectively?
- Were escalation procedures and contingency plans well-defined and executed when necessary?
- Were there any instances where risks were not identified or managed properly, leading to delays or issues in deliverables?

Exit Management Planning Audit Questions:

- Was an exit management plan included as a contractual deliverable?
- Did the plan outline responsibilities and cost allocations for both parties in the event of contract termination?
- If contract termination had occurred, was the exit management plan followed, and were financial closure activities completed appropriately?
- Were there any lessons learned from exit management planning and execution to improve future contract terminations?

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Solution Delivery

Primary Test: Contract Change and Request for Services (SD003.P)

Objective:

To evaluate the effectiveness of contract change (CC) management and Request for Services (RFS) approvals and oversight, taking into account the unique governance structure and potential control gaps that may arise outside IBM's standard systems and controls.

A CC is typically a change to the base contract affecting T&C, price, or delivery. A RFS is within the scope of the contract and may represent additional revenue or be counted as part of a committed revenue spend. Where RFS is outside the scope of the base contract, a CC will also be required. CCs and RFSs are equally subject to solution design and delivery processes. Review the requirements in the contract design and agreement process for CCs and RFSs as these agreements are subject to the same mandatory requirements dependent on clip levels and/or complexity.

Approach:

Obtain the universe of CCs and RFSs during the audit period. Identify high-risk samples based upon value, financial performance, sign date (close to quarter-end), complexity, penalties, or settlements, and select sample(s) to identify if change and request processes were followed.

- Review if RFSs impact service penalties, and that controls were in place to manage penalties.
- Have turnaround targets for CCs and RFSs been met? If not, is that identified with effective corrective action plans in place to address?
- Review the process to determine whether an RFS was chargeable or not. What controls were in place to assess whether an RFS was correctly treated? Ensure concessions were not being hidden by counting RFS work as in-scope.
- Assess whether any work was performed before the RFS was finalized and approved by both parties. Were there effective processes in place to identify and track pre-contract work or work at risk? Were there effective processes operating to manage and monitor any pre-approved pre-contract work to ensure it did not exceed business limits? For instance, where pre-contract work / work at risk is an integral part of the process to manage RFSs, check for bypasses and undetected bypasses of these processes to ensure no hours were worked without the customer's commitment and without additional billing where applicable.
- Review a sample of deliverables from RFSs and assess whether requirements or completion criteria were met, or whether additional work was performed outside of the scope of the RFS.
- Review the change management process to manage scope changes to RFSs and assess whether all the changes were correctly charged. Verify that changes to delivery processes required to manage CC and RFSs are incorporated into the management system.
- For contracts with significant RFS volumes, was there a management system implemented to monitor and track RFSs for cost and timescales?
- Where variances occur, was a root cause or common issue(s) identified and addressed in the solution delivery of future RFSs?
- Confirm that monitoring of RFSs was operating to identify operational delays and cost overruns.
- Assess whether the processes were in place to monitor potential RFS cost overruns prior to limits on RFS being reached (e.g., monitoring to highlight when 80% of the RFS costs were spent) and the processes were in place to mitigate against unauthorized over-spend.
- Confirm that baselines impacted by RFSs were correctly priced and adjusted using the CC process. For example, reduced resource charges (RRCs) may be an inappropriate mechanism for adjusting charges following an RFS which decommissioned a large number of servers. This could be particularly significant in a contract which includes benchmarking clauses. Look for RFSs which support significant expansion or contraction of the customer's business.

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Solution Delivery

Primary Test: Contract Change and Request for Services (SD004.P)

(continued)

Baseline Adjustments and Pricing Accuracy:

- Were any changes to contract baselines resulting from RFS activities appropriately priced and processed through the contract change mechanism within the entity?
- Have alternative pricing methods, such as Reduced Resource Credits (RRCs), been used inappropriately in cases involving substantial expansion or contraction of the customer's business within the entity?

RFS Consolidation into Contract Changes:

- Were RFSs regularly consolidated into formal contract changes to ensure accurate tracking, pricing, and contractual alignment?
- How effectively were RFSs integrated into the contract change management process?
- How was work at risk managed when it was an integral part of the RFS process?
- Were there any bypasses of work at risk controls, and if so, how were they addressed?
- For a sample of RFS deliverables, did the work performed meet the defined requirements?
- Were there instances of scope creep or additional work performed outside the original RFS? How were these changes identified, priced, and billed through the change management process?
- For contracts with high RFS volumes, was there a management system in place to monitor costs and timelines?
- How effectively were root causes or recurring issues identified and addressed in future solution design and delivery?
- Were changes to delivery processes, necessitated by RFS and contract changes, integrated into the management system?
- How effectively was RFS monitoring employed to detect operational delays and cost overruns?
- Were there mechanisms in place to notify stakeholders when predefined cost consumption thresholds were approached or exceeded (e.g., alerts when 80% of RFS budget is utilized), to prevent uncontrolled overruns?
- What processes were in place to escalate and address cost overruns or operational delays identified through RFS monitoring?
- How were lessons learned from RFS monitoring and cost control experiences used to improve future operational management and cost controls?

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Solution Delivery

Primary Test: Billing (SD004.P)

Objective:

To ensure that billing is in accordance with contract terms, and that invoices and credit notes were properly justified, approved and issued on a timely basis; and that no issues remain that impact the recovery of accounts receivable.

Approach:

- Had contract team documented the expected billing profile for the contract based on the contract terms and monitored that those terms were met. If not, was that identified and subsequently resolved. Determine the root cause.
- Was the correct billing information provided timely to those responsible for billing generation?
- Were credit notes, billing adjustments, and sales concessions correctly authorized? Assess whether supporting documentation has implications for the validity of revenue or cost recognition - in particular the timing for recognition of revenue or cost and assess whether the root cause of credit notes points to solution delivery issues.
- Identify billing suppression activities. Was the root cause pointing to solution delivery issues?
- Was the billing history showing any evidence of concessions or unauthorized commitments made, such as late or incomplete billing?
- Where variable consumption / resource unit billing was in place, have management or contract reviews been performed against source information to confirm accuracy?
- Was there monitoring and reconciliation of the service delivery process?
 - Were contract revenue and billing components reconciled accurately?
 - Were there any discrepancies between the contract and actual billing?
 - Were there proper controls in place to prevent overbilling or underbilling?
 - Were billing issues promptly identified, addressed, and resolved?
- Was there any contract baselines adjustment for additional/reduced resource charges (ARCs/RRCs) for billing accordingly?
- Where information supporting billing was managed by the customer, were controls in place to ensure the integrity of that information? In such an instance, were application controls in place to ensure the integrity of data received from customer systems?
- For baseline billing, review the process to confirm accuracy of baselines and adjust where necessary. Have baselines been agreed with the customer. Were there any disputes relating to the validity of baselines? Has technology supporting service delivery been amended since contract signing and has the impact been included in baseline adjustments?
- Is monitoring of all contractual baselines in place?
- Was there control in place to ensure that adjustment for billing was on a timely basis when there was volume increase or decrease (ARCs or RRCs)?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Solution Delivery

Primary Test: Accounts Receivable (SD005.P)

Objective:

To ensure that billing is in accordance with contract terms, and that invoices and credit notes were properly justified, approved and issued on a timely basis; and that no issues remain that impact the recovery of accounts receivable.

Approach:

- Were invoices generally paid in accordance with standard terms or do delays point to non-standard payment terms, dissatisfaction of deliverables, or potentially unauthorized extended payment terms?
- Determine the root cause of disputed invoices using reason codes and supporting narrative text on the dispute. Verify if it was related to solution delivery issues. Was there evidence that the solution did not match customer requirements? Was there evidence that deliverables were incomplete or late?
- Was there evidence of aged debt in conjunctions with/or suppressed late payment fees? If so, was there evidence that withheld payments were due to solution delivery issues or unauthorized payment terms (e.g., payment period being extended)?
- Were there any write-offs or concession adjustments (look for the write-off reason code or other general ledger adjustment) made in the system that indicate solution delivery issues?
- Were customer entities, accounts, or invoices in pre-legal or legal status with issues relating to solution delivery? Review the background, including communications between the entity and the customer, to determine the cause.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Solution Delivery

Primary Test: Labor Claiming and Work at Risk (SD006.P)

Objective:

To ensure that labor claiming was accurate and in accordance with the full labor recording guidelines and that controls were in place to ensure the integrity of billing and performance measurements.

To ensure that work did not commence prior to commitment from the customer or without following the required work-at-risk process. An assessment should be made of how the entity monitored unapproved work at risk, how liabilities were limited or contained by customers, and how violations were dealt with.

Approach:

Review labor claiming records and identify exception situations, including:

- Significant transfers between projects and contracts, indicating potential work at risk
- Net negative hours for employees on specific projects. Were processes in place to identify, validate, and rectify them?
- Excessive labor claiming (review average claiming by banding)
- Hours transferred between billable and non-billable activity codes including the transfer from vacation and education time to billable
- Significant gaps between when labor was performed and claimed
- Individuals with travel expenses incurred on dates when no labor was claimed
- Individuals with travel expenses and labor claimed on the same dates but different charge codes
- Claiming by individuals on behalf of others without the proper delegation/authorization or approval
- Time recorded against contracts which are re-opened during the audit period so that additional hours can be recorded. This could identify that revenue had been prematurely recognized against the original contract.
- Manipulation of utilization. For example, when a contract becomes troubled, it was allocated with excessive resources to artificially improve utilization metrics on other projects.

Review reports detailing project/RFS revenue and cost for situations that indicate issues in labor claiming. Identify projects with no costs, no revenue or excessive costs that may indicate:

- Hours recorded against expired or terminated contracts
- Billable hours not claimed against a billable claim code, with potential missed billing
- Hours worked against a project but not claimed or hours claimed but not worked

Review a sample of contract changes and RFS (as per test SD003.P) to identify work at risk:

- Review the management system in place to identify work started before contract. Assess the adequacy of that process where instances of significant work at risk exist.
- Review all correspondence for the RFS/contract change to determine if there was any indication of work being carried out prior to contract signature
- For approved work at risk, check for required approvals prior to commencement of work, including communications with the customer to limit liability. Review whether work continued after approvals, cost limits had expired / been exceeded.
- Assess whether controls were in place to monitor expiry of work at risk approvals.
- Assess the impact of work at risk on revenue recognition without a contract.
- Review where subcontractors have started work without a signed contract in place, or prior to the contract with the customer (Note: subcontractors can work at their own risk. If the entity requested the subcontractors to start work, and there would be potential procurement bypass.)

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 9. Solution Design

Objective:

To determine whether solutions developed by the entity were:

- Aligned with customer requirements as captured during the opportunity management process,
- Properly reviewed and approved by appropriate levels of management,
- Compliant with IBM guidelines and corporate instructions, ensuring consistency with enterprise standards.

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Risk/Exposure:

The design phase is a critical determinant of project success. It requires a comprehensive and realistic evaluation of all associated risks and costs—both internal and external, including vendor-related expenses. A foundational element of this phase is a clear and complete understanding of customer expectations, as captured during the opportunity management process.

For Acquired and Retained Entities not aligned with IBM's standard tools and processes, the absence of structured governance introduces significant risks. These include:

- Inadequate risk and cost assessment, potentially leading to underestimation of project scope or financial exposure.
- Insufficient review and approval of pricing elements and non-standard terms, which may result in legal vulnerabilities or contractual disputes.
- Misalignment with IBM's corporate guidelines and instructions, jeopardizing compliance, operational consistency, and brand integrity.
- Reduced visibility and oversight by the GPO, limiting IBM's ability to enforce standards and mitigate risks proactively.

To safeguard IBM's profitability and reputation, it is essential that solution design had rigorous evaluation, management approval, and alignment with IBM's enterprise-wide policies and controls.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 9. Solution Design

Primary Test: Contract Design and Agreement (DS001.P)

Objective:

To evaluate whether contracts were structured to meet contractual obligations, mitigate risks, and maintain compliance with enterprise standards.

Key areas of testing include:

- Customer Requirements Definition
Assess whether customer expectations were clearly and comprehensively defined during the opportunity management process and accurately reflected in the final contract.
- Alignment with Approved Solution Design
Verify that contract terms were consistent with all approved solution elements, including pricing, scope, and key business assumptions.
- Risk Mitigation and Legal Safeguards
Evaluate whether the contract structure provided clarity and enforceability, minimized legal and financial exposure, and supported profitability objectives.

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Approach:

Identification and Assessment of Non-Standard Clauses

Review contracts for the presence of clauses that may pose risks or require special handling, including but not limited to:

- Sweeper Clauses: Unrestricted commitments to undefined or unlimited services or liabilities, which may lead to cost overruns, scope creep, or unbilled services.
- Termination Provisions: Absence of punitive termination clauses that protect IBM's interests.
- Service Level Agreements (SLAs): Unrealistic performance targets or SLAs dependent on third parties outside IBM's control.
- Ambiguous Language: Vague or poorly defined terms that have led to extended negotiations or disputes.
- Retrospective Benchmarking: Clauses allowing post-contract performance comparisons that may affect pricing or delivery.
- Audit Access: Requirements for the entity or IBM to provide audit or investigation reports, or participate in customer audits, with associated cost and compliance implications.
- Minimum Revenue Guarantees: Terms that restrict the entity's ability to meet revenue thresholds or recover fixed costs, including "cherry-picking" of services by customers.
- Intellectual Property (IP) Rights: Provisions that may compromise the entity's or IBM's ownership or control over solution IP.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 9. Solution Design

Primary Test: Contract Design and Agreement (DS001.P)

(continued)

Contract Structure and Design Validation

- Confirm that the contract includes a clearly defined Statement of Work (SOW) with measurable acceptance criteria.
- Where only a high-level design is included, verify that timelines and responsibilities for completing detailed design are documented, and that provisions exist for charging additional work identified during final design.
- Ensure that contracts based on preliminary customer inventories include clauses allowing financial adjustments once final inventories are confirmed.
- For incremental business, assess whether changes to scope, deliverables, billing, and service levels are clearly defined and integrated into the base contract.
- Validate that the documented solution design is accurate, consistent, and aligned with the approved proposal.

GPO Oversight and Governance

- Confirm that the GPO has visibility into contract execution and design activities.
- Ensure that any deviations from IBM's standard contracting practices are escalated, reviewed, and approved in accordance with governance protocols.

Contract approvals

- Have all conditions in the approval of the contract (e.g., by Pricing, Legal, Accounting) been met?
- Check for any unapproved conditions inconsistent with the contract (e.g., side letters; written or verbal).
- Were the contracts signed and all approvals obtained before commencement of supply of service? If not, was there an approved letter of intent (LOI) or authorization to proceed (ATP) in place?
- Was there evidence that contract signatures had been back dated or the contract had been changed by the customer before signature?
- Have required opportunity learning reviews (formerly Win Loss reviews) have been conducted and documented according to the appropriate clip-level? Check that procedures were in use to disseminate lessons learned.

Data privacy considerations

If personal data is processed in another country, does the contract describe the data protection responsibilities, e.g., in Europe a separate European Union (EU) model clause is required before data is exported from the EU. The agreement to create these EU model clauses should be held in the main contract.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 9. Solution Design

Primary Test: Solution Design Mandatories (DS002.P)

Objective:

To determine whether opportunities have been progressed in accordance with IBM's mandatory processes and procedures, despite operating outside IBM's standard tools and systems. This includes verifying that:

- Required governance, approvals, and documentation standards were followed.
- Key activities—such as solution design, pricing, risk assessment, and contract development—were consistent with IBM's enterprise policies.
- Deviations from IBM's prescribed processes were identified, justified, and appropriately managed.

Approach:

Business Transaction Type (BTT) Validation

- Confirm that the BTT was accurately calculated and adjusted according to the contract negotiations.

Pricing and Approval Governance

- Verify that the pricing case received approval from appropriately delegated/authorized personnel.
- Where multiple lines of business were involved, ensure that approvals were based on a consistent understanding of the proposed solution.

Internal Approvals and Customer Due Diligence

- Confirm that all required internal approvals were obtained prior to making business commitments.
- Assess whether the customer's credit was evaluated and documented.
- Verify compliance with U.S. Export Regulations and the denied parties list validation.

Cross-Functional Review

- Where applicable, confirm that relevant functions—including Contract & Negotiation (C&N), Accounting, and other stakeholders—reviewed the solution and contract.

Contractual Terms and Supporting Documentation

- Ensure that T&Cs were appropriately selected and approved.
- Confirm that proposal and support plans were in place where required.
- Validate that customer requirements were clearly defined and that the solution design was accurately reflected in the contract and supporting statements of work.

Confidentiality and Inventory Management

- Review the Confidential Disclosure Agreement to ensure protection of sensitive information.
- Where a preliminary customer inventory was used, confirm that the contract included provisions for financial adjustment upon final inventory confirmation and that the inventory validation plan existed.

Solution Pricing and Complexity Considerations

- Confirm that the solution was priced and documented correctly and completely.
- Ensure that the pricing reflected the complexity of transition and transformation activities and included non-standard terms, like trade-ins, buybacks, demonstration equipment, and trial offerings.

Third-Party Product Safety Compliance

- Where OEM products were included, verify that Product Safety Review Board (PSRB) approval has been obtained for each product.

IBM Consulting Delegation

- Note that for IBM Consulting engagements, Partners may hold delegated authority to perform certain review and approval activities due to their end-to-end responsibility for solution delivery.

GPO Oversight

- Confirm that the GPO had appropriate visibility to opportunity management activities, and that any deviations from IBM's standard processes were escalated, reviewed, and managed in accordance with governance protocols.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Objective:

To assess whether the entity is operating in alignment with IBM's Procurement Policies and Practices, particularly in their role within the supply chain. The review will focus on evaluating whether procurement and accounts payable activities were conducted in a controlled, compliant, and value-driven manner, consistent with IBM's enterprise standards and contractual obligations.

Scope of Review:

- **Procurement Governance and Delegation:** Confirm that all procurement activities are performed either by authorized members of Global Procurement or by organizations that have received formal delegation of Procurement Authority from the Procurement Policy Executive.
- **Policy Compliance:** Review procurement processes, documentation, and controls to ensure adherence to IBM's Procurement Policies and Practices, including sourcing, vendor management, and contract execution.
- **Operational Alignment:** Evaluate whether procurement operations within the entity support IBM's strategic objectives and deliver value through effective use of people, processes, and technologies.

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Risk/Exposure:

- **Supplier Selection Risks:** excessive expenditures, strained supplier relationships, increased vulnerability to fraudulent activity which results in financial loss or disputes, and reputational and legal risks.
- **Purchase Order Process Weaknesses:** unauthorized or unapproved expenditures, cost overruns, and operational inefficiencies.
- **Approval of Commitments Risks:** excessive or unauthorized spending, legal exposure, and potential conflicts with vendor agreements.
- **Non-Purchase Order Activity Bypass:** unauthorized expenditures, increased costs, and vendor management challenges.
- **Vendor Integrity Concerns:** expose IBM to legal, financial, and reputational harm.
- **Accounts Payable (A/P) Risks:** inconsistent cashflow, incorrect financial recording, financial loss, and late payments may further lead to regulatory non-compliance or vendor dissatisfaction.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Supplier Selection (PR001.P)

Objective:

To validate that controls supporting the supplier evaluation and selection process were sufficient based on objective criteria, aligned with IBM's procurement policies, and designed to ensure that goods and services are acquired at optimal value.

Additionally, to assess if procurement activities were conducted in accordance with IBM's governance framework, and that appropriate documentation, approvals, and due diligence were in place to mitigate financial, operational, and reputational risks.

Approach:

Identify high-risk procurement activities and validate that purchases were made in accordance with IBM's procurement policies and control risk assessment (CRA) standards.

Key Activities:

- Spend Analysis and Risk Identification:
 - Utilize commodity and country-level spend reports to identify high-risk segments, including commodities with elevated spend, strategic importance, or known compliance concerns.
 - Identify instances where IBM Business Partners are also acting as vendors, which may present potential conflicts of interest.
 - Compile a list of newly onboarded vendors, including the nature of goods or services procured, and flag vendors with low-value or low-frequency transactions for further review.
- Sample Selection:
 - Select a representative sample of purchasing transactions from identified high-risk areas.
 - Include both high-value transactions (exceeding IBM's established procurement "clip levels" over a rolling 12-month period) and low-value or one-time purchases to assess control consistency across different procurement tiers.
- Control Testing and CRA Validation:
 - Test sampled transactions against IBM's sourcing criteria to validate compliance with approved procurement methods and CRA data.
 - Confirm that sourcing techniques used were authorized and aligned with IBM's procurement standards.
 - Any exceptions identified during the rolling 12-month spend analysis must be validated against IBM's annual clip levels (January–December), not on a rolling basis.
- Commodity-Specific Criteria:
 - Where applicable, apply additional supplier selection criteria based on the specific requirements of the commodity or service being sourced. These criteria should be identified through process walkthroughs and tested alongside general procurement controls.

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Supplier Selection (PR001.P)

(continued)

Supplier Selection

- Competitive Evaluation (With or Without Price Consideration)
 - Were evaluation criteria and weighting factors established in advance by the cross-functional team?
 - If price accounted for less than 50% of the evaluation criteria, was the rationale clearly documented and approved by procurement management?
 - Were vendors ranked based on the agreed criteria, and was the final selection approved by all members of the cross-functional team?
 - If the award was granted to a vendor other than the top-ranked candidate, was justification provided and procurement management approval obtained?
 - Was the minimum of two vendors considered in the evaluation?
 - Did both procurement and the business requestor participate in the cross-functional team?
 - Was a summary of the source selection analysis and decision documented (electronically or in hardcopy)?
- Competitive Bidding
 - Were requirements communicated simultaneously to all participating vendors?
 - Was a minimum of three valid responses received? If fewer responses were obtained, were the necessary approvals documented?
 - If the award was granted to a vendor other than the lowest bidder, was justification provided and management approval obtained?
 - Were any updates to the requirements or extensions of the due date communicated to all participating vendors at the same time?
 - Did late responses have the appropriate approval to be included in the selection process?
 - Were vendors advised of their selection or non-selection on a timely basis?
 - Was a summary of the source selection analysis and decision documented?
- Reverse auctions
 - A reverse auction is a type of auction where the buyer specifies what they want to buy, and the vendors bid for the business. They're based on the assumption that multiple vendors can provide the required product or service, and the supplier selection can be based 100% on obtaining the best price.
 - Was the incumbent vendor included? If not, was the reason documented?
 - Was there a minimum of three acceptable bidders (two for small and emerging countries)?
 - Were initial requirements communicated to all vendors at the same time?
 - Were vendors notified of their participation in the reverse auction?
 - Were the results of the analysis and decision documented?
- Sole-source or only source decisions:
 - Did documentation exist to indicate that there were no other alternatives available?
- Customer directed vendors:
 - Was there documentation (e-mail or letter) from the customer available to support that the supplier was customer specified? If not, was there documentation from the marketing/sales team to the customer confirming the customer's request to use a specific vendor? Was procurement copied on the e-mail or letter? See exceptions in the Blue Book under Customer Directed Suppliers for government accounts and personal computer purchases.
 - If a more competitive solution was available, did procurement offer it to the marketing or sales team ("client")?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Supplier Selection (PR001.P)

(continued)

- If the client declined the solution, was there adequate approvals received from the client's executive (director level and higher) and Finance line executive (director level and higher)?
 - Did procurement document and execute according to the client's direction?
 - Did procurement perform vendor assessment on POs with customer directed vendors? If not, was there documentation that vendor assessment was performed within sixty (60) calendar days of order placement?
- For U.S. based vendors
 - Was at least one diversity vendor included in any competitive selection technique?
- Was proliferation screening performed prior to transacting business with the vendor?
- For continuity of services re-evaluations
 - Did the extension exceed the length of time for the original commitment of fair value?

Fair Value Analysis

If Competitive Evaluation with price or Competitive Bidding was used for supplier selection, a separate fair value analysis is not required. Fair Value Analysis may be performed by using analytical technique - price comparison or cost buildup.

- Cost Comparison:
 - Was valid industry data or benchmark pricing information for the same or similar product or service used for the price comparison?
 - Was price of another IBM product or service for which the fair value had already been determined used in the comparison?
 - Was the pricing information used in the comparison current and relevant to the country/geography and time period of the comparison?
 - Was there a summary of the price comparison analysis and decision on the competitiveness of the price documented (electronically or hard copy)?
- Cost Buildup:
 - Was current and relevant industry/benchmark material costs and labor rates used to ensure the most competitive cost?
 - Were agreements with specified prices lists which were put in place by Sourcing Councils or other IBM locations used as part of the analysis?
 - Was the analysis performed by an independent individual or team (for example, a cost engineer or a cross-functional team which includes Procurement). If not, did the Procurement manager approve the Fair Value determination?
 - Was the summary of the Cost Buildup analysis and decision on the competitiveness of the price documented (electronically or hard copy)?
- Competitive evaluation with price - Separate Fair Value analysis not required.
- Competitive evaluation without price:
 - Was analytical technique (either price comparison or cost buildup) used to ensure a fair value determination?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Supplier Selection (PR001.P)

(continued)

- Competitive bidding and reverse auctions - Separate Fair Value analysis not required except in cases where the required minimum responses were not received, and it is not possible to re-bid.
 - Was the approval of the Global Commodity Chair or Country Procurement Manager obtained?
 - Were the justification and reasons documented, and fair value analysis performed using the approved analytical technique?
- Sole or Only Source:
 - Was analytical technique (either price comparison or cost buildup) used to ensure a fair value determination?
 - If the final price does not represent fair value, did the documentation demonstrate that the requestor was notified?
- IBM Business Partner, Alliance Partner or Supplier identifies opportunity (includes marketing alliances):
 - Was analytical technique (either price comparison or cost buildup) used to ensure a fair value determination?
 - If the fair value determines the Business or Alliance Partner is not competitive, did the procurement advise their client or the Business or Alliance Partner that if they don't become competitive, they may not be awarded future business?
 - Were the results of the fair value determination fully documented?
- Customer Directed:
 - Was analytical technique (either price comparison or cost buildup) used to ensure a fair value determination?
- For continuity of service re-evaluations, did the extension exceed the length of time for the original commitment of fair value?
- If an evergreen contract was used, were there specifications for how often fair value should be performed? If a contract had a specific expiration date, was fair value performed at the point of any extension?
- Was there a documented process in place to monitor vendor spending to consider when to renegotiate the prices, terms, or conditions?

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Purchase Order Process (PR002.P)

Objective:

To determine whether controls over the purchase order (PO) process were effective in ensuring that financial commitments were made only to valid, approved vendors. To verify that purchases were legitimate, properly authorized, and compliant with IBM's procurement policies and contractual obligations. Additionally, to verify that appropriate documentation and approvals were in place to safeguard IBM's financial and operational interests.

Approach:

Using data analysis and risk-based auditing techniques to select POs for testing. The samples should include both high-value transactions exceeding IBM's established procurement clip levels and low-volume or single purchases to ensure comprehensive coverage. Attributes to Test:

Business Justification and Classification:

- Was there a valid business purpose for the purchase?
- Was the appropriate commodity code applied?

Supplier Validation:

- Was the PO issued to a valid, approved vendor?

Approval Compliance:

- Were requester and procurement (or delegated authority) approvals obtained prior to vendor commitment?
- If approvals were obtained post-commitment (within 10 days), was justification documented?

Pricing Accuracy:

- Was the price consistent with the accepted arrangement (e.g., contract, price list, quote, or cost estimate)?

Terms and Conditions:

- Did the PO specify invoicing, payment, and delivery terms? Payment Reconciliation:
- Did the PO commitment amount match the actual payment(s)? PO Timing and Bypass Validation:
- Was the PO issued prior to the accounts payable invoice date?
- If not, was the PO coded as a bypass with a valid justification? Coding Accuracy:
- Was the PO properly coded?
- Was there a process to validate source code accuracy, and were any errors corrected promptly?

Fair Value Assessment:

- For bypass POs exceeding clip levels, was a fair value determination performed?

Change Management:

- Were changes to the PO properly approved by the requester, their manager, and procurement?

Cancellation Charges:

- Were cancellation fees appropriately approved? Premium Charges:
- Were premium freight or overtime charges approved by both the requester and procurement?

Delegation Compliance:

- Was there any evidence of circumvention of clip levels or delegation authority through multiple POs to the same vendor?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Purchase Order Process (PR002.P)

(continued)

- Obtain the Requisition Cycle Time Report to determine POs with large cycle time between requisition and PO placement. (Requisition processing more than 20 days). Determine if the requisition cycle time was greater than a specified local target (i.e., 10 days). Determine the causes for the delays.
- Obtain a report showing all POs for this entity that were changed from an exception code (PX, BX, PU, BU). Determine that these values were being counted in monthly exception spending measurements. Post approval should only be done when buyers are presented with short lead-time to place the order. Verify that management had reviewed these reports and had tested that fair value had been performed. From the reports, select a sample of POs that had fair value analysis performed after PO placement. Verify appropriate fair value documentation and that short lead-time pressures had existed.
- If unit-less purchase orders were used (the unit designation in SAP is 'UL'), request a list and select a sample for testing. Samples should focus on high-dollar value, purchases that were paid with multiple invoices, and purchases with descriptions that could be itemized into individual units. For each PO determine if:
 - The use of the UL designation was appropriate. Could the purchase have been defined in units?
 - Procurement was able to determine exactly what was purchased and performed any required fair value analysis.
 - Management implemented regular UL PO reviews. Review the methodology for selecting UL POs for this testing to ensure complete coverage of UL activity.
 - Controls were in place to verify that IBM received and was billed for only what was ordered through proper procurement channels. (The negative confirmation process with accounts payable is not sufficient since this will go to the requester.)
 - The measurements and use of UL designations complied with Procurement requirements.
- For any POs where early payment terms had been agreed to with a vendor, verify that procurement guidelines on discounts for early payments were followed.
- Review the local work authorizations (WAs) process and request a list of all WAs issued to vendors during the audit period.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Contract Administration (PR003.P)

Objective:

To assess whether contractual agreements established by the entity were effectively managed and structured to protect IBM's business and legal interests. To verify that contracts contained clearly defined scopes of work, appropriate business and legal clauses, measurable vendor performance criteria, and supporting documentation that demonstrates sound contract governance.

To validate the accuracy and reliability of data reported for agreement management metrics, ensuring that performance tracking aligns with IBM's standards and reporting expectations.

Approach:

Assess whether contracts managed by the entity were properly structured, approved, and maintained in accordance with IBM's Procurement Policies and Practices (the Blue Book). This includes validating the completeness of contract documentation, the clarity of scope and terms, and the effectiveness of controls supporting vendor relationships.

Select a judgmental sample of contracts based on risk indicators, such as strategic importance, sensitivity, financial exposure, vendor diversity, and regional relevance.

Key Evaluation Criteria:

1. Contract Approvals and Authority:

- Were all contracts (e.g., base agreements, statements of work, confidentiality agreements, equipment loan agreements) approved by line management, finance, legal, and procurement prior to the effective date?
- If approvals were obtained post-signature, was there any activity on the contract before final approval?
- Were approvals within delegated commitment authority?
- If a non-standard agreement was used, was legal approval obtained before submission to the client?

2. Contracts Acquired from Other Organizations:

- Was there a process to ensure that inherited contract files complied with IBM's Procurement Policies and Practices?
- Did acquired contracts contain complete documentation and meet IBM's standards?
- If deficiencies were identified, did the procurement team develop and execute an action plan to remediate and update the contracts?

3. Contract Structure and Content:

- Did the contract include all required terms and conditions?
- Was the scope of work clearly defined, including:
 - Defined job classifications for time and materials contracts
 - Defined job responsibilities for contractors
 - Reporting requirements to provide data for confirmation of services performed
 - Clauses regarding the use of subcontractors
 - Invoicing requirements

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Contract Administration (PR003.P)

(continued)

4. Compliance with Corporate Guidelines:
 - Did the contract comply with IBM's policies regarding business with former employees, close personal friends, or relatives to avoid conflicts of interest?
 - If an employee was permanently located at the vendor (or vice versa), did the contract include provisions to mitigate joint-employer risks?
5. Deliverables and Change Control:
 - Were deliverables clearly specified?
 - Was a formal change control process in place, identifying authorized individuals for contract and scope modifications?
6. Were cancellation terms and costs, and the methodology for determining settlement, clearly defined in the contract?
7. Were contract terms in accordance with quoted terms for price, delivery, quality, and discount?
8. If the audit clause had been exercised, were the results reviewed and actions taken where necessary?
9. Were contracts processed and loaded in a timely manner, i.e., were they held 'in-prep' greater than local targets?
10. Had the procurement contract owner established a process for validating that both the entity and the vendor had met all the commitments established in the contract? (This includes, but isn't limited to product deliverables, quality standards, timeliness of delivery, and safety and security location reviews that were required by the contract) If the procurement contract owner did not have direct control, determine if they required that the organization that did have direct control, also had established an auditable process to monitor both the entity's and the vendor's performance against commitments.? Or, had potential business risks been identified that could occur without this process in place?
11. Was there a means of comparing the current projected value of a contract against its original projected value? Review those contracts where the current projected value exceeds the original projected value by 20% or more and the delta is greater than \$1 million. Were these contracts re-evaluated to determine if the price, terms or conditions should be renegotiated? If there were exceptions to this requirement, were they reviewed by the procurement manager? NOTE: This question is applicable to only those contracts that identify a deliverable, usually the SOW (not the base agreements). Also, compare contracts with similar deliverables to verify that rate schedules are consistent for similar services.
12. Was there a process to review and approve contract change costs and cancellation costs?
13. Were the rates contained in the invoices consistent with the rates identified in the contracts and POs?
14. Were delivery and payment terms consistent with those in the contracts?
15. Were contracted rates similar for contracts with similar deliverables?
16. Were agreements to protect the privacy of the entity and vendor data in place for all e-procurement relationships?
17. Verify that all T&Cs of the contract were monitored and executed properly. If a contract clause required activity by the entity or the vendor, was that activity being performed (ex. insurance certificates, measurements, deliverables).
18. If this purchasing organization establishes, maintains, or owns contracts with external groups that provide contractors to the entity, verify Procurement has a process in place to educate contractor management and supervisory personnel on the entity's contractor guidelines. Select a sample of active agreements involving contractors and verify this education took place. This education should take place before contractors come to a facility of the entity and again as necessary to maintain proper awareness of the entity's contractor guidelines.
19. Review agreement management measurements for three consecutive months or quarters to identify agreements that were not properly executed and/or expired with current activity. Also, review trends for aged-in-prep and aged expired agreements.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Approval of Commitments (PR004.P)

Objective:

To verify that adequate controls were in place to ensure that financial commitments were properly authorized, accurately recorded, and aligned with corporate policies. To assess whether commitments were made to valid vendors, supported by appropriate documentation, and executed within delegated authority limits to safeguard IBM's financial interests.

Approach:

Assess whether adequate procedures for financial commitments was in place in compliance with Corporate Instruction FIN 101 and IBM's procurement governance framework. To validate approval processes, delegation of authority, and adherence to documented procedures.

Key Activities:

Procedure Review:

- Obtain copies of local procedures governing fund commitments.
- Validate that procedures require a minimum of two independent approvals:
 - Requester approval authorizing the release of funds.
 - Procurement approval confirming vendor selection, pricing, and terms and conditions.
- Confirm that procedures specify approval requirements for alterations based on changes in committed amounts.
- Test for proper approvals within the PO Process.

Delegation of Authority:

- Obtain copies of procurement delegation letters issued by the IBM Chief Procurement Officer.
- Verify adherence to delegated authority within the PO Process.

Delegated Procurement Oversight:

- Obtain a list of all organizations to which the procurement manager has delegated authority.
- Review the Document of Understanding (DOU) between the delegating and receiving organizations.
- Determine whether the procurement manager has established a formal review process to ensure compliance with the DOU.

Approval Monitoring for Contract Changes:

- Confirm that processes are in place to ensure approval levels are not exceeded when contracts are updated, renewed, or when scopes of work are modified.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Procurement Bypass (PR005.P)

Objective:

To determine whether the procurement function has established effective controls and monitoring processes to detect and prevent circumvention of standard procurement procedures. To evaluate the use of check requests, expense accounts, and electronic check requests to ensure that purchases were not made outside of approved procurement channels.

To assess whether there were effective mechanisms to identify and address bypass activity, enforce compliance with IBM's procurement policies, and maintain the integrity of the sourcing process.

Approach:

Obtain a listing of all check requests, corporate purchase card transactions, invoice only payments and expense account exceptions for the audit period for the entity and select risk-based samples for review.

- Confirm that check requests were for valid business purposes?
- Was there monitoring of check requests to identify purchases that should have been made using purchase orders?
- For purchases made using the corporate purchase (credit) card, verify that multiple purchases of the same product were not made from the same vendor within the same time period.
 - Confirm that supporting documentation existed to validate the receipt of goods or services.
 - Determine if a process was in place to reconcile monthly statements received by management and that timely corrective action was taken for identified discrepancies.
- For expense account exceptions, examine transactions for purchases that should have been made through procurement. The focus of the test is solely on procurement bypass. Any other expense account errors should be documented and presented locally to management; however, full testing of expense account transactions would occur during an Employee Payables engagement. Verify that:
 - There were no improper charges for entertainment of vendor personnel.
 - Goods and services were not paid for on an employee expense reimbursement that should have been procured using a purchase order.
- For invoice only payments, determine if there was a process to notify the line organization of any improper purchases made without purchase orders?
- For the purchase orders tested in the sample, were all POs that were coded as a bypass listed and reported as bypasses?
- For all instances of noted bypass (purchase orders, expense accounts, check requests, etc.) was the initiator of these requests contacted by management with a request to use procurement services?
- Were appropriate actions taken to bypass offenders and their management chain?
- Did bypasses above the delegated clip levels have documentation to support fair value analysis and management approvals?
- Was fair value analysis performed for bypasses that were over the appropriate clip level?
- Was quarterly testing of non-purchase order categories performed?

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Supplier Assessment (PR006.P)

Objective:

To determine whether adequate controls were in place to ensure that the supplier assessment process was effective and supported the selection of vendors that delivered the best overall value.

Approach:

- Supplier Screening Against Restricted Lists
 - Was the vendor screened against the following lists prior to engagement:
 - Denied Parties
 - Unapproved Suppliers
 - Sensitive Customers
 - Partnership Program Participants
 - If the vendor appeared on any of these lists:
 - Was prior approval obtained before proceeding?
 - For vendors listed under the Partnership Program, was the relevant partnership executive notified in cases of significant activity?
- Certification Evaluation
 - Were vendors assessed for ISO 14001 (Environmental Management) and ISO 9001 (Quality Management) certifications?
- Shipping Procedural Compliance
 - Did procurement provide the vendor with Shipping Procedural Instructions (SPIs) for each destination country?
- Supplier Documentation
 - Were the Supplier Assessment Form and Supplier Questionnaire from the Procurement website completed for all new vendors?
- Financial Risk Assessment
 - Were current financial reports (e.g., Dun & Bradstreet) used to evaluate vendor financial health?
 - Did procurement define acceptable levels of financial risk?
 - If a vendor exceeded acceptable risk thresholds, were monitoring plans and business justifications documented?
- Supplier Capability Evaluation
 - Were new vendors assessed for their ability to meet the following criteria:
 - Financial solvency
 - Compliance with government regulations (including export controls)
 - Alignment with IBM's technology and quality standards
 - Capacity to meet IBM's operational requirements
- Security Compliance
 - Was the IBM Security Letter Agreement (SECLA) signed in accordance with the requirements outlined in the IBM Blue Book?
- If we use the vendor only for small amounts or a low number of transactions, identify the reason why we could not use our core vendors. Verify for fraudulent activities, especially in areas where we have purchased consulting services. Especially watch for vendors that were sole source or customer directed.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Accounts Payable (PR007.P)

Objective:

To validate if effective controls were in place to ensure accurate and timely payments processed to vendors, consistent with purchasing commitment, with required approvals obtained, and with proof of receipt while optimizing free cash flow.

Approach:

Vendor Master File (VMF) Maintenance

- Review procedures for additions, changes, and deletions to the file of valid vendors to identify and eliminate duplicate vendor records. Was there appropriate separation of duties? Does someone have an overwriting authority?
- Run a report to identify vendor records added or updated with payments incurred during the audit period. Select a sample based on the transaction amount, payment method, blocking flags, discount flag, invoice status, vendor name, and payment term to test against the following controls.
 - Denied party list (DPL) and unauthorized supplier list (USL) check
Note: Requesters should perform the check. A/P should perform back-end checks against DPL (whenever the DPL was updated) and USL (monthly).
 - Was there a procedure to validate the appropriateness of requests for VMF updates with valid supporting documentation/data sources? Were approvals obtained for exceptions?
 - Were proposed vendors checked against employee/payroll records based on employee names? Was there appropriate validation for a match? Reconcile the bank account against Payroll.
- Were proposed vendors checked against existing ones to identify potential duplicate entries? (similar names, addresses, bank account numbers, Dun & Bradstreet (Dunning number), tax identification number, and payment method)
- Was a report run to check pay term record mismatches between VMF and actual payment?
- Run a query to identify vendors on VMF without payment activity for the past 30 months. Select a sample to test whether the deletion or block performed timely and the deleted one had open POs.

Processing Controls

- Review the process for vendor invoice processing and identify risk-based samples for review. Analyses to identify risk indicators: timeliness of payments, accuracy of discounts, excessive payments beyond commitment amounts, invoices with non-zero withholding tax, invoices with gross amounts not equal to net amounts plus withholding tax amounts, PO using non-PO commodity code to pay, incorrect commodity code used.
- Verify the validity and completeness (date and time stamped, address, or value-added tax as regulated) of invoices addressed to the entity and the effectiveness of the revalidation check which should ensure invoice line-item amounts, discounts taken, and any applicable sales taxes agree to the total invoice value processed.
- Were procedures in place to identify duplicate payments? Identify potential duplicate payments for testing, sort the invoice amount by supplier and by invoice number, and check invoices of same vendors with identical amounts or similar invoice numbers.
- Validate the payment (amount, early payment discount, and payment terms) match the system input, invoice, and order commitment (reference number, quantity, unit and total price, start and end date of service rendered, tax rate and amount, and payment terms)? Did controls exist to prevent payments exceeding the allowable variances and were these referred to Procurement for approval?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 10. Vendor Management

Primary Test: Accounts Payable (PR007.P)

(continued)

- Check if verification of goods and/or services received was properly done, required approvals were obtained, and the correct commodity code was used.
 - If the verifications of receipt could not be done, check if there were adequate secondary controls to safeguard against inappropriate payments.
 - Were all verifications of receipts requesting blocking of invoice payments promptly processed? Were the blocked invoices tracked and reported to ensure prompt resolution?
 - When applicable, affirm that the approvals matched FIN 101 requirements (such as a requirement by local country financial delegation).
- Were there controls over debit memorandums to offset against vendor payments or prevent processing of a duplicate debit on receipt of the subsequent credit note from the vendor?
- Were procedures in place to review invoices with expedited payment terms to ensure these terms are warranted prior to payment processing?
- Were procedures in place to handle vendor claims? Were claims for short-shipments and returned goods properly handled and resolved? Verify that credit notes were received and processed on a timely basis and are deducted from subsequent payments.
- Review the level of urgent payments, final demands, and legal situations. Investigate reasons for exceptions and determine whether process deficiencies exist.

A/P Bank Reconciliations

- Obtain a list of bank accounts used for A/P. For each account, review the bank-to-ledger reconciliations for a period of at least two consecutive months. Reconciliations should be performed within accounting cut-off deadlines to ensure any corrective entries were reflected within the correct accounting period. Confirm that reconciliations were timely and accurate and properly approved by an authorized approver and actions were taken for any variances. In addition, check that reconciling items were measured, reported, and cleared in a timely manner. Verify that the individual responsible for bank reconciliations was not also responsible for A/P or disbursement activities.

Disbursement Controls

- Review procedures for handling cheques and other negotiable instruments. Did controls exist over the ordering, receipt, inventory and custody of cheques and blank forms? These should include restricted access to stocks of cheques; sequence controls to account for usage; independent monthly reconciliations of cheque stocks to new cheque issues and payments made; controls over access to approval signature plates; separation of duties.
 - Review monthly reconciliation log of blank check forms - review beginning and end check numbers.
 - Review bank acknowledgement files and reconcile the payment report (bank reference and IBM reference numbers).
 - Ensure process in place to recover funds and payments was correct. If not, there was appropriate documentation in place to recover funds.
- Review procedures for handling returned payments. Suggested items to review: timeliness of deposit, accounting entries, documentation of reason, corrective action taken, change to vendor master file made if appropriate, duties properly separated. Were returned payments logs maintained?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 11. Facilities Operations (includes Energy Management and Safety)

Objective:

To validate if a framework exists for planning, scheduling, and prioritizing building and equipment maintenance to ensure that facilities were safe, secure, and in accordance with procedures and guidelines. To validate if adequate controls were exercised to protect the assets (i.e., maintenance equipment, materials, and supplies) and if inventory control disciplines were implemented.

To validate if the safety guidelines and policies are appropriately executed and monitored. If there is any real estate projects/transactions associated with the entity, verify whether the required approvals were obtained per IBM Corporate Organization Letter 111 Delegation of Authority – Real estate.

To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Risk/Exposure:

Insufficient enforcement of planning, scheduling, and prioritizing building and equipment maintenance could lead to disruption in the operation and potential safety exposures. Failure to have control and accountability of assets (i.e., maintenance equipment, materials, and supplies) coupled with insufficient inventory control disciplines could result in failure to detect loss, improper financial reporting, and potential tax exposures.

Failure to comply with legal, safety requirements, and insufficient enforcement of guidelines and policies in accordance with local country and IBM safety guidelines combined with an inadequate process to monitor and address issues could lead to employee safety issues resulting in employee dissatisfaction, impact to IBM's image, and financial loss.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 11. Facilities Operations (includes Energy Management and Safety)

Primary Test: Primary Test: Building Maintenance and Operations (FO001.P)

Objective:

To validate if a framework exists for planning, scheduling, and prioritizing building and equipment maintenance to ensure that facilities are safe, secure, and in accordance with procedures and guidelines. To verify that the GPO has appropriate oversight to ensure that deviations from IBM processes were identified, assessed, and managed in accordance with governance expectations.

Approach:

Review policies and procedures at facilities where the entity operates its own real estate services and verify that:

- The preventative maintenance (PM) program was in accordance with established procedures and guidelines. The program should ensure that facilities are clean and safe, and building equipment is maintained in accordance with manufacture requirements.
- Management's methods for determining what items require preventative maintenance were adequate.
- There were current techniques for planning, scheduling, and prioritizing which services are adequate for the orderly management and control of facility work projects.
- Validate the effectiveness of the facility management (FM) contractor program: proper oversight and performance monitoring means.
- Were there periodic self-assessments and tracking of deviations to closure to ensure compliance with internal and regulatory requirements?
- Was there a method to report and track facility-related requests that would ensure timely closure of all items?
- Facility Projects were generally valued at less than \$200,000 and involved routine office renovation/relocation of nonstructural building partitions, minimum electrical and mechanical changes, general maintenance and repair work). Facility Projects do not include design effort for completion.

Select a sample of facility projects and verify that there is a means of authorizing and validating work performed by the vendor.

- Were appropriate approvals received prior to commencement of work?
- Was there a method for tracking the entire projects expenditures?
 - Was a cost estimate prepared?
 - Were plan-to-actual costs tracked?
 - Was the project verified as properly completed?
 - Were charges properly validated?
- Did the facility project manager consider if the job would have an environmental impact and if so, did they complete the Environmental Program Initiation Checklist (EPIC) form and obtain necessary approval from the local environmental contact?

ACQUIRED AND RETAINED ENTITIES
AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 11. Facilities Operations (includes Energy Management and Safety)

Primary Test: Assets (FO002.P)

Objective:

To validate if adequate controls are exercised to protect assets (i.e., maintenance equipment, materials, and supplies), and inventory control disciplines have been implemented to ensure the proper use and control of these items.

Approach:

- Review policies and procedures and verify that:
 - Adequate control is exercised over the ordering, issuance, use, and safeguarding of maintenance equipment, materials, and supplies.
 - Periodic, physical inventory taking was performed, and out-of-line situations were addressed.
 - Approval requirements were met for any write-offs or sale of Furniture and Fixtures (F&F), Leasehold Improvements (LHI), Machinery and Equipment (M&E), I/T Network and Fine and Facility Artwork.
- For unique assets (i.e., power tools, vehicles, test equipment, etc.) at the site that are not tracked by the property tracking system, review the control requirements.
- Select a sample of assets and physically verify physical existence.
 - Match serial numbers from assets to the local inventory records when inventories are required by Fixed Asset Accounting requirements and/or the vendor contract.

ACQUIRED AND RETAINED ENTITIES AUDIT PROGRAM #50-70-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 11. Facilities Operations (includes Energy Management and Safety)

Primary Test: Safety (FO003.P)

Objective:

To validate if safety guidelines and policies are appropriately executed and monitored to ensure safety for the workplace and employees.

Approach:

- Did the acquired locations have two fire/life safety compliant and accessible means of egress?
- Review the location's facility practices to ensure the building was managed to prevent accidents and incidents and review the location's methodology for handling facility-related maintenance orders. Are there practices in place to ensure that the facility is maintained to prevent employee slips, trips, and falls and that the facility egress paths and stairwells are adequately illuminated and maintained to allow for safe emergency exit from the facility. To include review items, such as:
 - Maintenance of walking surfaces via the elimination of uneven walking surface transitions, frayed carpeting, uneven/missing raised floor tiles, openings/holes/cracks/depressions/ projections in walking surfaces or curbing, slippery/wet/icy walking surfaces, and any potential tripping hazard.
 - Maintenance of stairwells and stairs via the elimination of broken stair treads, improper rail guards, improper handrails, slippery/wet/icy steps, and any potential tripping hazards.
 - Contracted inspection and maintenance of escalators/elevators to prevent potential injury.
- Is there a practice in place to protect employees from slips, trips, and falls (such as cones, stanchions, hazard tape) during activities such as: wet-method floor cleaning, maintenance activities, demolition/construction activities, work beneath raised floor tiles, or inclement weather?
- Is there a practice in-place for the reporting and tracking of facility-related requests to ensure that any facility repairs needed are completed in a timely manner?
- Review the fire/life safety program and related documentation.
 - Building Design – Verify that there is a practice in place to ensure that all existing buildings, modifications to existing buildings, new buildings, acquisitions, and new leases meet local fire and life safety regulations, building codes, and IBM Fire and Life Safety Fundamentals. Should there be a conflict, the more stringent requirement shall take precedence.
 - Maintenance – Verify there is an inspection/test and maintenance program, as specified in local/national codes and insurance schedules, for the following:
 - Fire pumps and controls, doors/stairwell doors (including closers), dampers, extinguishers or suppressant systems, protection initiating devices, notification devices, and detection panels.
 - Sprinkler system and control valves as per Corporate Instruction FIN 178.
 - Public address system and other emergency communication equipment, if required as part of the life safety or fire alarm system.
 - Exit signage.
 - Emergency lighting and associated batteries and/or life safety generators.
 - Other fire and life safety equipment.
 - System Impairment – Are there controls established to prevent unauthorized impairment of essential fire safety and life safety equipment?
 - Fire Prevention – Is there a fire prevention program implemented to address work practices that minimize the likelihood and consequences of fire?
- Request the most recent annual submission of the applicable Professional Self-Assessments (PSA) from the non-integrated entity to determine if:
 - Were reviews performed timely and recorded in Chief Sustainability Office (CSO) TRIRIGA?
 - From the PSA Checklist, select a sample of line items and review the documentation that supported the “Complies”, “Complies with minor deviations”, “Unsatisfactory”, “Pending”, “Not applicable” responses.